

COMPLIANCE RISK ANALYSIS

medplum

<https://github.com/medplum/medplum>

Scanned 2026-03-23 · OpenDocket V1 · Primary: Claude Sonnet · Review: Gemini 1.5 Flash

IMPORTANT LIMITATIONS OF THIS REPORT

This report is not legal advice and is not defensible in court. It provides directional guidance only. To obtain a defensible compliance assessment, engage a licensed attorney and certified auditor.

Scope limitations: Only public repository content was analyzed. Infrastructure configuration, deployment settings, operational policies, vendor contracts, and staff training are outside scope.

A true compliance audit would also review: vendor contracts and BAAs, staff training records, incident response procedures, physical security controls, and system audit logs — none of which are visible in source code.

RISK ASSESSMENT

This analysis identified 56 compliance risk patterns across GDPR, HIPAA, PCI-DSS, SOC2, SOX, TCPA. Of these, 47 are classified as high-severity — patterns consistent with potential non-compliance that regulators actively investigate. The most serious gaps were found in GDPR, TCPA, PCI-DSS. Without remediation, these patterns could expose the organization to regulatory enforcement, financial penalties, and reputational damage.

CRITICAL RISK

47 high-severity patterns found — immediate attention required

WHAT THIS MEANS IF UNADDRESSED

FRAMEWORK	REGULATORY BODY	MAX PENALTY	ENFORCEMENT TREND
GDPR	EU DPAs	Up to EUR 20M or 4% turnover	Cross-border enforcement rising
TCPA	FCC	\$500-\$1,500 per violation	Class action filings at record levels
PCI-DSS	PCI SSC	Fines \$5K-\$100K/month	v4.0 enforcement accelerating

TOP FINDINGS

HIGH RISK

GDPR GDPR-001 SECURITY.md:15

The development team must conduct a comprehensive data processing audit to identify all personal data processing activities within the system, then document the specific lawful basis under GDPR Article

HIGH RISK

HIPAA HIPAA-001 .github/labeler.yml:38

Implement and document technical safeguards required under HIPAA Security Rule §164.312(a)(1) including access controls, audit controls, integrity controls, person authentication, and transmission sec

HIGH RISK

PCI-DSS PCIDSS-002 .github/CODEOWNERS:2

Implement strong encryption for cardholder data at rest using AES-256 or equivalent cryptographic standards, and ensure all cardholder data transmission uses TLS 1.2+ with strong cipher suites. Replac

INDEPENDENT REVIEW — GEMINI 1.5 FLASH

0

Confirmed

0

Context dependent

0

Possible false positives

0

Additional risk

Primary: Claude Sonnet (Anthropic). Review: Gemini 1.5 Flash (Google). Neither constitutes legal advice.

RECOMMENDED ACTIONS

HIGH The development team must conduct a comprehensive data processing audit to identify all personal data processing activities within the system, then document the specific lawful basis under GDPR Article 6 (such as consent, legitimate interest, or vital interests) for each activity. This documentation should be implemented in code comments, configuration files, or a dedicated privacy configuration module that maps each data processing function to its corresponding lawful basis. Additionally, ensure that consent mechanisms are properly structured to meet GDPR requirements rather than just medical consent standards.

GDPR · GDPR-001

HIGH Implement a comprehensive consent management system that includes: (1) clear consent collection interfaces that separately address data processing purposes beyond medical treatment, (2) granular consent options allowing users to consent to specific data processing activities, (3) plain language explanations of what data is collected and how it's used, (4) easily accessible consent withdrawal mechanisms, and (5) audit trails for all consent decisions. The existing medical treatment consent forms should be supplemented with dedicated GDPR consent flows for data processing activities.

GDPR · GDPR-002

HIGH Implement a user-facing data deletion API endpoint and corresponding UI components that allow authenticated data subjects to request deletion of their personal data. This should include mechanisms to verify the requestor's identity, validate erasure requests against legitimate grounds under Article 17, handle cascading deletions across related records, and provide confirmation of successful deletion. Consider implementing soft-delete patterns with audit trails to demonstrate compliance while maintaining data integrity for ongoing legal obligations.

GDPR · GDPR-003

HIGH Implement data portability functionality that allows authenticated users to request and receive their personal data in structured formats (JSON, CSV, XML). This should include: API endpoints for data export requests, user interface components for initiating data exports, mechanisms to package personal data across all system components, and clear documentation of supported export formats. The system should also support transmitting this data directly to other controllers when technically feasible, and maintain audit logs of all portability requests.

GDPR · GDPR-004

HIGH Implement a comprehensive data breach detection and notification system that includes: automated monitoring for unauthorized access to personal data, breach classification and risk assessment workflows, automated notification mechanisms to supervisory authorities within 72 hours, and systems for notifying affected data subjects without undue delay. This should include audit logging, breach incident tracking, notification templates, and integration with relevant data protection authorities' reporting systems. Document these processes and ensure they cover both automated detection and manual breach reporting procedures.

GDPR · GDPR-006

HIGH Implement comprehensive data retention policies that cover all personal data types processed by the Medplum platform, not just CI/CD artifacts. Add automated deletion or anonymization workflows triggered when data retention periods expire or processing purposes are fulfilled. Configure data lifecycle management rules in the Clinical Data Repository (CDR) with clear retention schedules based on healthcare regulatory requirements and business purposes. Document retention periods for different data categories and implement monitoring to ensure automated compliance with storage limitation requirements.

GDPR · GDPR-007

HIGH Implement and document appropriate GDPR Chapter V transfer mechanisms before deploying to AWS regions outside the EEA. This requires either: (1) implementing Standard Contractual Clauses with AWS as the data processor, (2) documenting reliance on adequacy decisions where applicable, or (3) obtaining explicit user consent for transfers with appropriate disclosures. Add configuration files or documentation that clearly specify which transfer

safeguards apply to each AWS region deployment, and ensure all cross-border data flows are mapped and legally justified under one of the Chapter V transfer mechanisms.

GDPR · GDPR-008

HIGH

Conduct and document a comprehensive Data Protection Impact Assessment as required by GDPR Article 35 for high-risk data processing activities. The DPIA should evaluate privacy risks associated with processing patient health data, BMI tracking, clinical observations, and cross-system patient identifiers. Document the assessment results, risk mitigation measures, and ongoing monitoring procedures. Include DPIA documentation in the project repository and ensure it's reviewed whenever processing activities change significantly.

GDPR · GDPR-009

HIGH

Implement comprehensive privacy notices that clearly identify the data controller, specify purposes for processing personal data, and inform users of their rights under GDPR. Create a privacy policy accessible through the application that covers data collection at the point of capture (Article 13) and when data is obtained from other sources (Article 14). Add privacy notice components to user-facing interfaces, particularly in the Medplum Auth system and any data collection points in the web application.

GDPR · GDPR-010

HIGH

Implement and document technical safeguards required under HIPAA Security Rule §164.312(a)(1) including access controls, audit controls, integrity controls, person authentication, and transmission security. Add encryption at rest and in transit, role-based access controls, audit logging mechanisms, and secure authentication systems. Document these safeguards in the codebase with clear implementation evidence, particularly for the patient data handling components identified in the foomedical example application.

HIPAA · HIPAA-001

HIGH

Implement explicit transport-level encryption controls for all PHI transmissions by configuring TLS 1.2+ with NIST-approved cipher suites across all application endpoints. Replace all HTTP endpoints in configuration files (particularly docker-compose.full-stack.yml and CI/CD workflows) with HTTPS equivalents, and add code documentation demonstrating compliance

with NIST SP 800-52 guidelines for secure transport protocols. Establish mandatory HTTPS redirects and disable insecure protocol versions to ensure all PHI transmissions occur over encrypted channels.

HIPAA · HIPAA-003

HIGH

The development team must implement and document technical access controls that explicitly restrict access to ePHI based on granted access rights. This includes implementing role-based access controls, user authentication mechanisms, and authorization checks within the FHIR access policy module. The OAuth implementation should be configured to enforce granular permissions, and access control policies must be clearly defined and implemented in the `accesspolicy.ts` file. Additionally, technical documentation demonstrating how these controls prevent unauthorized access to ePHI should be created and maintained.

HIPAA · HIPAA-004

HIGH

Implement automatic session timeout functionality for all user-facing applications that access PHI. This should include configurable inactivity timeouts (typically 15-30 minutes for healthcare applications), automatic session termination when timeouts are reached, and proper session state cleanup. Add session timeout configuration to authentication components, middleware, or application settings, and ensure the timeout values are appropriate for healthcare workflows while meeting HIPAA requirements.

HIPAA · HIPAA-005

HIGH

Implement explicit minimum necessary access controls throughout the system by adding role-based data filtering that restricts PHI queries and responses based on user permissions and purpose of use. Add audit logging for all PHI access attempts with justification tracking. Enhance the existing FHIRPath filtering functions to automatically apply minimum necessary restrictions based on the requesting user's role and the specific healthcare workflow context. Document and enforce policies that define what constitutes "minimum necessary" for each user role and use case, then implement these as enforceable technical controls in the API layer.

HIPAA · HIPAA-007

HIGH

Implement documentation and configuration controls that demonstrate BAA compliance for all third-party integrations. This should include: (1) adding configuration files or code comments that reference executed BAAs for each

third-party service, (2) implementing runtime checks to ensure only BAA-compliant services can access PHI, (3) creating a registry of approved business associates in the codebase, and (4) adding validation logic that prevents data transmission to services without proper BAA status verification. Consider adding environment variables or configuration flags that explicitly track BAA compliance status for each integration.

HIPAA · HIPAA-008

HIGH

Implement comprehensive data retention and disposal policies that specifically address PHI lifecycle management. Create documented procedures for secure deletion of PHI from all storage media, including databases, backups, and temporary files. Establish secure media sanitization protocols before hardware reuse or disposal, with verification procedures. Add audit logging for all PHI deletion operations and implement automated retention enforcement mechanisms that comply with required retention periods before secure disposal.

HIPAA · HIPAA-009

HIGH

Implement a comprehensive security incident detection and response system that includes automated monitoring for suspicious activities involving PHI, incident logging mechanisms, notification procedures for security breaches, and documented response workflows. Additionally, establish emergency access procedures that allow authorized personnel to access PHI during system outages or disruptions while maintaining audit trails. This should include backup authentication methods, emergency user provisioning processes, and clear documentation of when and how emergency access can be invoked.

HIPAA · HIPAA-010

HIGH

The development team must implement adequate PAN protection controls before any cardholder data storage occurs. This requires: (1) implementing strong cryptographic methods to render any stored PAN unreadable (encryption with proper key management, irreversible hashes with strong cryptographic functions, or tokenization), (2) ensuring PAN is never stored in clear text anywhere in the system, (3) documenting the specific protection methods used, and (4) conducting a comprehensive code review to verify no PAN storage exists without proper protection. If PAN storage is not actually required for business operations, consider eliminating storage entirely and using payment processor tokens instead.

PCI-DSS · PCIDSS-001

HIGH

Implement strong encryption for cardholder data at rest using AES-256 or equivalent cryptographic standards, and ensure all cardholder data transmission uses TLS 1.2+ with strong cipher suites. Replace all HTTP endpoints with HTTPS equivalents in configuration files, particularly in `docker-compose.full-stack.yml` for base URLs and health checks. Update timestamp services in GitHub workflows to use HTTPS instead of HTTP. Document encryption key management procedures and ensure proper cryptographic controls are in place throughout the application stack.

PCI-DSS · PCIDSS-002

HIGH

Implement comprehensive role-based access controls that specifically restrict cardholder data access to only authorized personnel based on job function requirements. This should include documented access policies, user role definitions tied to business needs, regular access reviews, and technical controls that enforce these restrictions at the application and data layers. The existing FHIR access policy should be enhanced to include specific cardholder data protection mechanisms, and all access control implementations should be clearly documented and auditable.

PCI-DSS · PCIDSS-003

HIGH

Implement dedicated network segmentation controls to create a clearly defined CDE boundary. This should include configuring network security groups, VPC isolation, subnet segregation, and firewall rules that restrict traffic flow between the CDE and other network segments. Document the network topology showing segmented zones, implement ingress/egress filtering rules, and ensure that only authorized systems can communicate with the CDE. Consider using Kubernetes network policies, cloud provider security groups, and dedicated VPCs/VNets to achieve proper isolation.

PCI-DSS · PCIDSS-004

HIGH

Implement comprehensive audit logging that captures: (1) all individual access attempts to cardholder data with user identification, timestamps, and data elements accessed; (2) all actions performed by users with root or administrative privileges including login attempts, configuration changes, and system modifications; and (3) all access to audit logs themselves including who viewed, modified, or deleted audit records. Configure automated log generation that cannot be disabled by users, ensure logs are

stored securely with integrity protection, and establish real-time monitoring for suspicious access patterns.

PCI-DSS · PCIDSS-007

HIGH

Implement comprehensive cryptographic key management procedures including automated key generation, secure distribution mechanisms, encrypted storage with proper access controls, scheduled rotation policies, and secure destruction processes. Remove all hardcoded keys and secrets from source code and migrate to a proper secrets management system (the Azure Key Vault reference in charts/values.yaml:12 suggests infrastructure exists but implementation is incomplete). Establish formal key management policies documenting the entire key lifecycle, implement proper key escrow procedures, and ensure all cryptographic operations follow documented procedures with audit trails for key management activities.

PCI-DSS · PCIDSS-008

HIGH

Implement a comprehensive third-party service provider management program that includes: documented agreements with all service providers that handle cardholder data (including cloud services, CI/CD platforms, and monitoring tools), regular security assessments of these providers, contractual requirements for PCI DSS compliance where applicable, and ongoing monitoring of third-party access to cardholder data environments. Create a formal vendor inventory and risk assessment process, and ensure all third-party integrations include appropriate security controls and audit trails.

PCI-DSS · PCIDSS-009

HIGH

The organization must develop and document a comprehensive incident response plan that specifically addresses cardholder data breach scenarios. This plan should include detailed procedures for breach detection (automated monitoring, alerting mechanisms), containment steps (isolation of affected systems, access controls), and notification requirements (timelines for notifying card brands, acquirers, and relevant parties). The plan should be documented in the repository's security documentation and include clear escalation paths, roles and responsibilities, and communication templates for breach scenarios.

PCI-DSS · PCIDSS-010

HIGH

The development team needs to provide evidence of implemented user authentication controls including: authentication middleware or handlers, user session management, access control lists or role-based permissions, password policies, multi-factor authentication capabilities, and login/logout functionality. Code files should demonstrate how the system validates user credentials, manages user sessions, and enforces access restrictions. Documentation of the OAuth/OpenID implementation mentioned in the README should be accompanied by actual source code that shows these authentication mechanisms are properly implemented and configured.

SOC2 · SOC2-001

HIGH

Implement comprehensive security event logging throughout the application, including audit trails for authentication, authorization, data access, and system changes. Add monitoring services that can detect anomalous behavior patterns, unauthorized access attempts, and security-relevant system events. Configure alerting mechanisms that notify security personnel of potential incidents in real-time. Ensure all security events are logged with sufficient detail (timestamps, user identification, actions performed, resources accessed) and stored in a centralized, tamper-evident logging system that supports compliance reporting and incident investigation.

SOC2 · SOC2-004

HIGH

Implement comprehensive incident response capabilities including: automated security event detection and logging systems, formal incident classification and escalation procedures, documented response workflows with defined roles and responsibilities, incident tracking and case management systems, and recovery procedures with defined RTO/RPO objectives. Additionally, establish security event monitoring dashboards, alerting mechanisms for security incidents, and regular testing of incident response procedures to ensure timely identification and remediation of security events.

SOC2 · SOC2-006

HIGH

Implement a comprehensive third-party risk management program including: automated dependency vulnerability scanning tools integrated into CI/CD pipelines, documented vendor risk assessment procedures for all service providers, regular security assessments of critical dependencies, and establishment of criteria for evaluating and monitoring third-party risks. Add

dependency check workflows to GitHub Actions that fail builds on high-severity vulnerabilities, maintain an inventory of all third-party services with associated risk ratings, and create formal vendor management policies that address security requirements and ongoing monitoring obligations.

SOC2 · SOC2-007

HIGH

Implement comprehensive data backup and recovery controls including: automated backup schedules for all critical data stores, database replication configurations, disaster recovery runbooks, backup verification procedures, and recovery time/point objectives (RTO/RPO) documentation. Add infrastructure-as-code configurations that define backup policies, cross-region replication for critical systems, and automated recovery testing procedures. Document these controls in your repository with clear procedures for data recovery scenarios.

SOC2 · SOC2-008

HIGH

Implement multi-factor authentication controls throughout the system, especially for administrative and privileged accounts. This should include configuring MFA in the authentication service, adding MFA enforcement in deployment configurations, implementing MFA requirements in the OAuth/OpenID authentication flows mentioned in the documentation, and ensuring all administrative interfaces require second-factor authentication. Documentation and configuration files should clearly demonstrate MFA implementation and enforcement policies.

SOC2 · SOC2-009

HIGH

The organization needs to create and document formal security policies covering acceptable use of systems and data, data classification standards, and access management procedures. These policies should be stored in accessible locations within the repository (such as a dedicated security or policies directory) and referenced in the main README.md. The policies must go beyond development practices to address organizational security governance, user responsibilities, data handling requirements, and access control principles that demonstrate the entity's commitment to integrity and ethical values as required by the trust services criteria.

SOC2 · SOC2-010

HIGH

Implement comprehensive financial data integrity controls including: automated validation rules for financial transactions, audit logging for all

financial data modifications, role-based access controls for financial systems, data completeness checks, reconciliation processes, and automated testing of financial calculation accuracy. Additionally, establish documented procedures for financial data governance, implement change management controls for financial reporting systems, and create monitoring dashboards to track data integrity metrics that support SOX 302 management certification requirements.

SOX · SOX-001

HIGH

Implement proper financial system access controls including: role-based access control (RBAC) configurations that specifically restrict financial data access, multi-factor authentication requirements for financial system users, documented authorization matrices showing who can access what financial data, audit logging of all financial system access attempts, and segregation of duties controls that prevent unauthorized financial data manipulation. These controls should be coded into the application layer, not just the CI/CD pipeline level.

SOX · SOX-002

HIGH

Implement a complete audit logging system that captures all financial transactions, data modifications, and user access events with tamper-evident controls. This should include cryptographic integrity protection, immutable log storage, detailed transaction metadata (user, timestamp, before/after values), and retention policies that meet SOX requirements. Ensure the audit system covers all financial data flows, not just the code deployment timestamping that currently exists.

SOX · SOX-003

HIGH

Implement branch protection rules requiring pull request approvals from different individuals than the code author. Add required reviewers for deployment workflows, particularly for the deploy.yml workflow. Remove or restrict workflow_dispatch triggers for production deployments, replacing them with approval-gated processes. Implement role-based access controls in GitHub that separate development permissions from deployment permissions, ensuring no single user can both commit code and execute production deployments.

SOX · SOX-005

HIGH Implement comprehensive data retention policies and technical controls specifically for financial records and audit documentation. This should include database-level retention settings, automated archival processes, and policy documentation that explicitly addresses SOX Section 802 requirements. Configure retention periods of at least 7 years for all financial data, audit logs, and supporting documentation. Consider implementing immutable storage solutions and automated compliance monitoring to ensure ongoing adherence to retention requirements.

SOX · SOX-006

HIGH Implement and document a comprehensive internal controls framework for financial reporting. Create formal documentation that includes: (1) clearly defined control objectives for financial data accuracy and completeness, (2) specific control activities such as segregation of duties, authorization procedures, and data validation controls, and (3) monitoring procedures including regular testing and evaluation of control effectiveness. Establish a dedicated controls documentation directory with version control, and ensure all financial reporting processes have corresponding control documentation that can be audited and verified.

SOX · SOX-007

HIGH Implement comprehensive financial record protection controls including: (1) immutable audit logging with cryptographic integrity verification for all financial data operations, (2) tamper detection mechanisms that monitor and alert on unauthorized access attempts to financial records, (3) role-based access controls specifically governing financial record modifications, and (4) backup and retention policies that prevent unauthorized destruction of financial documents. Replace any data truncation operations affecting financial records with secure archival processes that maintain complete audit trails while meeting regulatory retention requirements.

SOX · SOX-008

HIGH Implement a comprehensive SMS consent collection system that includes: (1) clear and conspicuous disclosure language explaining that consent is being sought for marketing text messages, (2) opt-in mechanisms that capture express written consent before sending any promotional SMS, (3) database fields to store and track consent status per user, and (4) validation logic to prevent SMS marketing to users without proper consent. The consent flow

should be separate from medical treatment consent and specifically address SMS marketing communications with appropriate legal disclaimers about message frequency and data rates.

TCPA · TCPA-001

HIGH

Implement a comprehensive opt-out system that includes: (1) clear opt-out instructions in all outbound messages (e.g., "Reply STOP to opt out"), (2) database tables to track recipient opt-out preferences, (3) API endpoints to process and honor opt-out requests, (4) automated message filtering to prevent sending to opted-out recipients, and (5) confirmation messages when opt-out requests are processed. Ensure opt-out requests are honored immediately and that the mechanism is prominently displayed in all messaging interfaces.

TCPA · TCPA-002

HIGH

Implement National Do Not Call Registry checking functionality by integrating with the FTC's Do Not Call Registry API or a third-party compliance service before initiating any outbound calls or SMS messages. Create and maintain an internal suppression list database table to track opt-out requests from users. Add validation logic in the communication workflow code to check both the national registry and internal suppression list before placing calls or sending messages. Ensure all outbound communication modules include these compliance checks as mandatory steps that cannot be bypassed.

TCPA · TCPA-003

HIGH

Implement a comprehensive messaging compliance system that includes: (1) user-facing disclosure forms showing expected message frequency before consent collection, (2) database schema to store user consent with disclosed frequency rates, (3) rate limiting mechanisms that enforce the disclosed frequency limits, and (4) logging systems to track message sending patterns for compliance auditing. The system should present clear frequency expectations (e.g., "up to 5 messages per week") during signup and technically enforce these limits in the messaging infrastructure.

TCPA · TCPA-004

HIGH

Implement sender identification functionality for all outbound messages by adding required fields such as sender name, organization identity, and contact information (phone number, email, or physical address). Create message templates or wrapper functions that automatically include this

identification data before sending any communications. Establish configuration settings to manage sender contact details and ensure they are consistently applied across all messaging channels. Add validation to prevent messages from being sent without proper sender identification.

TCPA · TCPA-005

HIGH

The development team needs to implement comprehensive consent record fields within the existing Consent and Consent_History tables to capture: (1) precise timestamp of consent collection, (2) method of consent (web form, SMS, voice, etc.), (3) the exact consent language/script shown to the consumer, (4) consumer contact information, and (5) any consent withdrawal records. Additionally, implement data retention policies ensuring these records are preserved and easily retrievable for regulatory inquiries or disputes, with proper indexing for efficient lookup by consumer identifier and date ranges.

TCPA · TCPA-006

HIGH

Implement a comprehensive consent revocation system that monitors for revocation requests through multiple channels (SMS replies, email responses, web forms, phone calls). The system should use flexible natural language processing to detect revocation intent beyond specific keywords (e.g., "STOP", "UNSUBSCRIBE", "REMOVE ME", "NO MORE"). Build automated workflows to process revocation requests within 24-48 hours maximum, maintain revocation logs with timestamps, and ensure revoked consent is immediately honored across all communication channels. Include testing frameworks to verify revocation handling works correctly under various scenarios.

TCPA · TCPA-007

HIGH

Implement time-of-day validation controls that check recipient local time zones before sending any outbound calls or messages. This should include: (1) recipient timezone detection/storage, (2) validation logic that prevents communications outside 8:00 AM - 9:00 PM windows, (3) queuing mechanisms to defer messages until permitted hours, and (4) integration of these controls into all outbound communication pathways including the appointment reminder bots and any other messaging systems. The existing scheduling infrastructure in the codebase could be extended to support these TCPA compliance requirements.

TCPA · TCPA-008

MEDIUM

Implement comprehensive data protection by design measures including: automated data minimization controls that limit data collection to stated purposes, retention period enforcement mechanisms, privacy impact assessment integration in development workflows, and systematic access controls that default to minimal data exposure. Add configuration options that enable privacy-protective defaults, implement data pseudonymization where possible, and establish clear data lifecycle management processes that demonstrate compliance with Article 25's requirements for both technical and organizational measures.

GDPR · GDPR-005

MEDIUM

Update security documentation to specify the exact AES implementation (AES-128, AES-192, or AES-256), document key management procedures including key generation, storage, rotation, and destruction processes as required by NIST SP 800-111. Provide technical implementation details showing how encryption keys are protected and managed. Review the base64 usage in lab integration components to ensure developers understand the distinction between data encoding and encryption. Consider implementing automated compliance checks to verify encryption configurations match documented standards.

HIPAA · HIPAA-002

MEDIUM

Implement comprehensive audit logging that captures all PHI access, creation, modification, and deletion events. This should include detailed audit trails with user identification, timestamps, data accessed, and actions performed. Enhance the existing AuditEvent framework to automatically log all FHIR resource interactions involving PHI. Add audit log review procedures

and automated monitoring capabilities. Document the complete audit control implementation including hardware, software, and procedural mechanisms as required by the standard.

HIPAA · HIPAA-006

MEDIUM

Implement comprehensive security testing controls including: (1) Add security-focused static analysis tools like CodeQL, Semgrep, or Snyk to CI/CD pipelines beyond basic ESLint; (2) Establish documented penetration testing procedures and schedule regular assessments; (3) Address security anti-patterns by replacing `exec()` calls in `packages/agent/src/app.ts:67` and `packages/cli/src/auth.ts:120` with safer alternatives, and reviewing `eval()` usage in `packages/core/src/fhirlexer/parse.ts`; (4) Implement formal code review processes that specifically check for security vulnerabilities before deployment.

PCI-DSS · PCIDSS-006

MEDIUM

The development team should provide detailed documentation and code review of the FHIR access policy implementation to demonstrate how user roles are defined, how permissions are mapped to specific system functions and data access, and how the principle of least privilege is enforced throughout the application. Additionally, expand access control implementation beyond GitHub workflows to cover all application components, ensuring that each user role has only the minimum permissions necessary to perform their authorized functions.

SOC2 · SOC2-002

MEDIUM

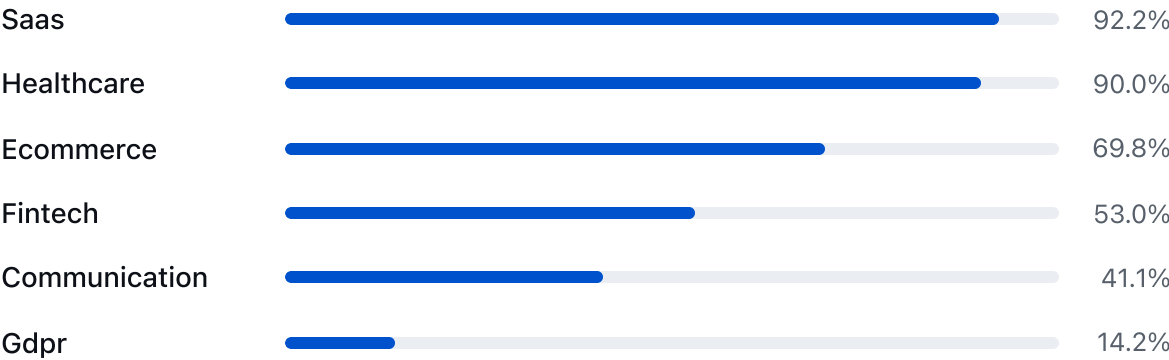
Implement and document formal change management procedures including: mandatory code review requirements through GitHub branch protection rules, automated testing workflows that must pass before deployment, formal approval processes for production deployments, and clear separation of duties between development and production environments. Add documentation describing the complete software development lifecycle process, testing requirements, and deployment controls to demonstrate compliance with SOX Section 404 IT general controls for change management.

SOX · SOX-004

RISK SCORECARD

FRAMEWORK	HIGH RISK	MEDIUM	CONCERN	NO ISSUE
GDPR	9	1	0	0
HIPAA	8	2	0	0
PCI-DSS	8	1	1	0
SOC2	7	1	2	0
SOX	7	1	0	0
TCPA	8	0	0	0

DOMAINS DETECTED



FRAMEWORK:

All (56)

GDPR (10)

HIPAA (10)

PCI-DSS (10)

SOC2 (10)

SOX (8)

TCPA (8)

SEVERITY:

All

High (47)

Medium (6)

Concern (3)

GDPR

10 findings

EU DPAs · Up to EUR 20M or 4% turnover

GDPR-001

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
SECURITY.md:15 - Data Handling - Medplum is in full compliance with
GDPR and has support for data deletion.
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:470
linkId: 'consent-for-treatment',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:471
text: 'Consent for Treatment',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:475
linkId: 'consent-for-treatment-signature',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:476
text: 'I the undersigned patient (or authorized representative, or
parent/guardian), consent to and
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:480
linkId: 'consent-for-treatment-date',
examples/medplum-chat-demo/data/example/example-data.json:2687
"display": "consent override"
examples/medplum-chat-demo/data/example/example-data.json:2735
"display": "legal guardian consent author"
```

FINDING

Does this system process personal data of EU residents, and if so, is there evidence that a lawful basis for processing under Article 6 GDPR has been identified and implemented for each processing activity?

REMEDIATION

The development team must conduct a comprehensive data processing audit to identify all personal data processing activities within the system, then document the specific lawful basis under GDPR Article 6 (such as consent, legitimate interest, or vital interests) for each activity. This documentation should be implemented in code comments, configuration files, or a dedicated privacy configuration module that maps each data processing function to its corresponding lawful basis. Additionally, ensure that consent mechanisms are properly structured to meet GDPR requirements rather than just medical consent standards.

GDPR-002

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/chromatic.yml:58 autoAcceptChanges: 'main'
.github/workflows/madge.yml:76 Please fix the listed circular module
dependencies so that your PR can be accepted. Thank you!
LICENSE.txt:135 the terms of any separate license agreement you may
have executed
LICENSE.txt:144 agreed to in writing, Licensor provides the Work (and
each
LICENSE.txt:156 negligent acts) or agreed to in writing, shall any
Contributor be
LICENSE.txt:171 of any other Contributor, and only if You agree to
indemnify,
LICENSE.txt:165 9. Accepting Warranty or Additional Liability. While
redistributing
LICENSE.txt:167 and charge a fee for, acceptance of support,
warranty, indemnity,
```

FINDING

Does the system implement consent collection mechanisms that satisfy the conditions for consent under Article 7, including freely given, specific, informed, and unambiguous indication of the data subject's wishes, with capability to withdraw consent?

REMEDIATION

Implement a comprehensive consent management system that includes: (1) clear consent collection interfaces that separately address data processing purposes beyond medical treatment, (2) granular consent options allowing users to consent to specific data processing activities, (3) plain language explanations of what data is collected and how it's used, (4) easily accessible consent withdrawal mechanisms, and (5) audit trails for all consent decisions. The existing medical treatment consent forms should be supplemented with dedicated GDPR consent flows for data processing activities.

GDPR-003

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
examples/medplum-demo-bots/src/adt-transfer-listener/adt-sftp-  
listener.ts:76  stream.destroy();  
examples/medplum-demo-bots/src/lab-integration/receive-oru-  
message.ts:297  stream.destroy();  
examples/medplum-demo-bots/src/spaces-bots/fhir-visualizer-bot.ts:269  
6. ✖ Forgetting to aggregate categorical data into counts  
packages/agent/src/bytestream.test.ts:101  client.destroy();  
packages/agent/src/bytestream.test.ts:176  client.destroy();  
packages/agent/src/bytestream.test.ts:249  client.destroy();  
packages/agent/src/bytestream.test.ts:326  client.destroy();  
packages/agent/src/bytestream.test.ts:409  client.destroy();
```

FINDING

Does the system implement the right to erasure (right to be forgotten) under Article 17, allowing data subjects to request deletion of their personal data without undue delay?

REMEDIATION

Implement a user-facing data deletion API endpoint and corresponding UI components that allow authenticated data subjects to request deletion of their personal data. This should include mechanisms to verify the requestor's identity, validate erasure requests against legitimate grounds under Article 17, handle cascading deletions across related records, and provide confirmation of successful deletion. Consider implementing soft-delete patterns with audit trails to demonstrate compliance while maintaining data integrity for ongoing legal obligations.

GDPR-004

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/scorecard.yml:63 # (Optional) Uncomment file_mode
if you have a .gitattributes with files marked export-ignore
Dockerfile:7 # The archive files are decompressed and extracted into
the specified destinations.
Dockerfile:9 # See:
https://docs.docker.com/reference/dockerfile/#adding-local-tar-
archives
eslint.config.mjs:5 export default defineConfig(medplumEslintConfig);
examples/foomedical/postcss.config.mjs:21 export default config;
examples/foomedical/src/App.tsx:16 export function App(): JSX.Element
| null {
examples/foomedical/src/Router.tsx:32 export function Router():
JSX.Element {
examples/foomedical/src/components/Footer.tsx:7 export function
Footer(): JSX.Element {
```

FINDING

Does the system provide data subjects the right to receive their personal data in a structured, commonly used, and machine-readable format, and to transmit that data to another controller, as required under Article 20?

REMEDIATION

Implement data portability functionality that allows authenticated users to request and receive their personal data in structured formats (JSON, CSV, XML). This should include: API endpoints for data export requests, user interface components for initiating data exports, mechanisms to package personal data across all system components, and clear documentation of supported export formats. The system should also support transmitting this data directly to other controllers when technically feasible, and maintain audit logs of all portability requests.

GDPR-005

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/scorecard.yml:2 # by a third-party and are governed
by separate terms of service, privacy
SECURITY.md:70 We consider security research conducted under this
policy to be authorized and will not pursue or su
SECURITY.md:13 - Encryption - Data is encrypted in transit with TLS
1.2 and 1.3. Data is encrypted at rest with AES
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:504
linkId: 'notice-of-privacy-practices',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:505
text: 'Notice of Privacy Practices',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:509
linkId: 'notice-of-privacy-practices-help',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:510
text: 'Sample Hospital Notice of Privacy Practices gives information
about how Sample Hospital may u
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:514
linkId: 'notice-of-privacy-practices-signature',
```

FINDING

Does the system demonstrate evidence of data protection by design and by default, implementing appropriate technical and organizational measures to ensure only necessary personal data is processed, as required under Article 25?

REMEDIATION

Implement comprehensive data protection by design measures including: automated data minimization controls that limit data collection to stated purposes, retention period enforcement mechanisms, privacy impact assessment integration in development workflows, and systematic access controls that default to minimal data exposure. Add configuration options that enable privacy-protective defaults, implement data pseudonymization where possible, and establish clear data lifecycle management processes that demonstrate compliance with Article 25's requirements for both technical and organizational measures.

GDPR-006

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
LICENSE.txt:158  incidental, or consequential damages of any character
arising as a
README.md:1  # [Medplum](https://www.medplum.com) &middot; [!GitHub
license](https://img.shields.io/badge/licens
SECURITY.md:14  - Continuous Monitoring - Independent third-party
penetration, threat, and vulnerability testing.
SECURITY.md:27  - Continuous Monitoring - We continuously monitor our
security and compliance status to ensure there
biome.json:31  "suspicious": {
examples/foomedical/README.md:11  <img
src="https://sonarcloud.io/api/project_badges/measure?
project=medplum_foomedical&metric=alert_s
examples/foomedical/package.json:25  "@mantine/notifications":
"8.3.18",
examples/foomedical/src/main.tsx:5  import { Notifications } from
'@mantine/notifications';
```

FINDING

Does the system implement mechanisms for detecting personal data breaches and notifying the supervisory authority within 72 hours and affected data subjects without undue delay, as required under Articles 33 and 34?

REMEDIATION

Implement a comprehensive data breach detection and notification system that includes: automated monitoring for unauthorized access to personal data, breach classification and risk assessment workflows, automated notification mechanisms to supervisory authorities within 72 hours, and systems for notifying affected data subjects without undue delay. This should include audit logging, breach incident tracking, notification templates, and integration with relevant data protection authorities' reporting systems. Document these processes and ensure they cover both automated detection and manual breach reporting procedures.

GDPR-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/auto_assign.yml:9 - mattlong
.github/workflows/build.yml:383 retention-days: 30
.github/workflows/codeql-analysis.yml:27 - cron: '30 14 * * 4'
.github/workflows/scorecard.yml:73 retention-days: 5
.github/workflows/scorecard.yml:13 - cron: '22 11 * * 3'
.github/workflows/upgrade-dependencies.yml:17 - cron: '0 9 * * 1'
Dockerfile:7 # The archive files are decompressed and extracted into
the specified destinations.
Dockerfile:9 # See:
https://docs.docker.com/reference/dockerfile/#adding-local-tar-
archives
```

FINDING

Does the system implement data retention policies that limit the storage of personal data to what is necessary for the specified processing purpose, with automated deletion or anonymization when the purpose is fulfilled, consistent with the storage limitation principle under Article 5(1)(e)?

REMEDIATION

Implement comprehensive data retention policies that cover all personal data types processed by the Medplum platform, not just CI/CD artifacts. Add automated deletion or anonymization workflows triggered when data retention periods expire or processing purposes are fulfilled. Configure data lifecycle management rules in the Clinical Data Repository (CDR) with clear retention schedules based on healthcare regulatory requirements and business purposes. Document retention periods for different data categories and implement monitoring to ensure automated compliance with storage limitation requirements.

GDPR-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-deb.yml:67  aws-region: ${ secrets.AWS_REGION
}}
.github/workflows/build-deb.yml:67  aws-region: ${ secrets.AWS_REGION
}}
.github/workflows/build-helm-charts.yml:44  aws-region: ${ secrets.AWS_REGION }}
.github/workflows/build-helm-charts.yml:44  aws-region: ${ secrets.AWS_REGION }}
.github/workflows/deploy.yml:55  aws-region: ${ secrets.AWS_REGION }}
.github/workflows/deploy.yml:74  AWS_REGION: ${ secrets.AWS_REGION }}
.github/workflows/deploy.yml:55  aws-region: ${ secrets.AWS_REGION }}
.github/workflows/deploy.yml:74  AWS_REGION: ${ secrets.AWS_REGION }}
```

FINDING

Does the system implement appropriate safeguards for transfers of personal data to third countries or international organizations, such as Standard Contractual Clauses or adequacy decisions, as required under Chapter V?

REMEDIATION

Implement and document appropriate GDPR Chapter V transfer mechanisms before deploying to AWS regions outside the EEA. This requires either: (1) implementing Standard Contractual Clauses with AWS as the data processor, (2) documenting reliance on adequacy decisions where applicable, or (3) obtaining explicit user consent for transfers with appropriate disclosures. Add configuration files or documentation that clearly specify which transfer safeguards apply to each AWS region deployment, and ensure all cross-border data flows are mapped and legally justified under one of the Chapter V transfer mechanisms.

GDPR-009

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.gitignore:105 # 0x profiling data
LICENSE.txt:57 and issue tracking systems that are managed by, or on
behalf of, the
examples/medplum-demo-bots/src/bmi-calculation-bot/README.md:21 -
Allows tracking BMI changes over time
examples/medplum-demo-bots/src/bmi-calculation-bot/README.md:59 -
**If BMI calculation succeeds**: The bot creates a new BMI observation
with the calculated value (
examples/medplum-demo-bots/src/bmi-calculation-bot/bmi-calculation-
bot.ts:179 // Create a new BMI observation (allows tracking BMI over
time)
examples/medplum-demo-bots/src/pre-commit-hook-bot-boolean.ts:33 *
tracking purposes.
examples/medplum-demo-bots/src/pre-commit-hook-bot-boolean.ts:42 //
Add Medplum identifier to the patient for tracking
examples/medplum-demo-bots/src/pre-commit-hook-bot-resource.ts:17 * -
Adds bidirectional identifiers for tracking
```

FINDING

Does the system process personal data in a manner likely to result in high risk to data subjects, and if so, is there evidence that a Data Protection Impact Assessment has been considered, as required under Article 35?

REMEDIATION

Conduct and document a comprehensive Data Protection Impact Assessment as required by GDPR Article 35 for high-risk data processing activities. The DPIA should evaluate privacy risks associated with processing patient health data, BMI tracking, clinical observations, and cross-system patient identifiers. Document the assessment results, risk mitigation measures, and ongoing monitoring procedures. Include DPIA documentation in the project repository and ensure it's reviewed whenever processing activities change significantly.

GDPR-010

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:162 endpoint:
https://eus.codesigning.azure.net/
.github/workflows/publish.yml:288 endpoint:
https://eus.codesigning.azure.net/
LICENSE.txt:116 of the NOTICE file are for informational purposes
only and
LICENSE.txt:37 copyright notice that is included in or attached to
the work
LICENSE.txt:97 (b) You must cause any modified files to carry
prominent notices
LICENSE.txt:102 attribution notices from the Source form of the Work,
LICENSE.txt:103 excluding those notices that do not pertain to any
part of
LICENSE.txt:106 (d) If the Work includes a "NOTICE" text file as part
of its
```

FINDING

Does the system provide transparent information to data subjects about the processing of their personal data, including identity of the controller, purposes of processing, and data subject rights, as required under Articles 13 and 14?

REMEDIATION

Implement comprehensive privacy notices that clearly identify the data controller, specify purposes for processing personal data, and inform users of their rights under GDPR. Create a privacy policy accessible through the application that covers data collection at the point of capture (Article 13) and when data is obtained from other sources (Article 14). Add privacy notice components to user-facing interfaces, particularly in the Medplum Auth system and any data collection points in the web application.

HIPAA

10 findings

HHS / OCR · Fines up to \$1.5M/year per category

HIPAA-001

HIGH RISK ▾**REGULATORY STANDARD****EVIDENCE**

```
.github/labeler.yml:38  medications:
.gitignore:23  packages/graphiql/public/
.gitignore:23  packages/graphiql/public/
README.md:102  |  └─ graphiql          # Preconfigured GraphiQL
README.md:102  |  └─ graphiql          # Preconfigured GraphiQL
SECURITY.md:23  - Security Awareness Training - Our team members are
required to go through employee security awaren
SECURITY.md:57  - Social engineering, phishing, or physical attacks
against Medplum employees, users, or infrastru
SECURITY.md:66  Our philosophy on this is aligned with the principles
outlined in Troy Hunt's post on "Beg Bounties,
```

FINDING

Does this system collect, store, process, or transmit individually identifiable health information as defined under 45 CFR §160.103, and if so, are adequate technical safeguards in place to protect the confidentiality of such Protected Health Information?

REMEDIATION

Implement and document technical safeguards required under HIPAA Security Rule §164.312(a)(1) including access controls, audit controls, integrity controls, person authentication, and transmission security. Add encryption at rest and in transit, role-based access controls, audit logging mechanisms, and secure authentication systems. Document these safeguards in the codebase with clear implementation evidence, particularly for the patient data handling components identified in the foomedical example application.

HIPAA-002

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
SECURITY.md:13 - Encryption - Data is encrypted in transit with TLS
1.2 and 1.3. Data is encrypted at rest with AES
SECURITY.md:13 - Encryption - Data is encrypted in transit with TLS
1.2 and 1.3. Data is encrypted at rest with AES
SECURITY.md:55 - Reports of insecure SSL/TLS ciphers or protocol
versions.
SECURITY.md:13 - Encryption - Data is encrypted in transit with TLS
1.2 and 1.3. Data is encrypted at rest with AES
charts/values.yaml:12 # type: "azure:keyVaultURL:secretName"
examples/medplum-demo-bots/src/billing-bots/superbill.test.ts:13
import { randomUUID } from 'crypto';
examples/medplum-demo-bots/src/epic/epic-query-patient.test.ts:20
import { generateKeyPairSync } from 'crypto';
examples/medplum-demo-bots/src/epic/epic-query-patient.ts:6 import {
createPrivateKey, randomBytes } from 'crypto';
```

FINDING

Is electronic Protected Health Information encrypted when stored at rest using methods consistent with NIST Special Publication 800-111, as required for addressable implementation under the HIPAA Security Rule?

REMEDIATION

Update security documentation to specify the exact AES implementation (AES-128, AES-192, or AES-256), document key management procedures including key generation, storage, rotation, and destruction processes as required by NIST SP 800-111. Provide technical implementation details showing how encryption keys are protected and managed. Review the base64 usage in lab integration components to ensure developers understand the distinction between data encoding and encryption. Consider implementing automated compliance checks to verify encryption configurations match documented standards.

HIPAA-003

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/CODEOWNERS:2 # See:
https://docs.github.com/en/repositories/managing-your-repositorys-
settings-and-features/custo
.github/workflows/add-issue-to-project.yml:21 project-url:
https://github.com/orgs/medplum/projects/1
.github/workflows/add-issue-to-project.yml:25 project-url:
https://github.com/orgs/medplum/projects/3
.github/workflows/build-agent.yml:50 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:52 # See:
https://github.com/actions/cache/blob/cdf6c1fa76f9f475f3d7449005a359c84ca
.github/workflows/build-agent.yml:93 * Taken from
https://github.com/dlemstra/code-sign-action
.github/workflows/build-agent.yml:162 endpoint:
https://eus.codesigning.azure.net/
.github/workflows/build-agent.yml:231 registry-url:
'https://registry.npmjs.org'
```

FINDING

Are all transmissions of electronic Protected Health Information encrypted using transport-level security consistent with NIST guidelines, preventing unauthorized access during transmission across electronic communications networks?

REMEDIATION

Implement explicit transport-level encryption controls for all PHI transmissions by configuring TLS 1.2+ with NIST-approved cipher suites across all application endpoints. Replace all HTTP endpoints in configuration files (particularly docker-compose.full-stack.yml and CI/CD workflows) with HTTPS equivalents, and add code documentation demonstrating compliance with NIST SP 800-52 guidelines for secure transport protocols. Establish mandatory HTTPS redirects and disable insecure protocol versions to ensure all PHI transmissions occur over encrypted channels.

HIPAA-004

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:22 - packages/server/src/oauth/**/*  
.github/labeler.yml:24 - packages/server/src/fhir/accesspolicy.ts  
.github/workflows/add-issue-to-project.yml:11 permissions:  
.github/workflows/add-issue-to-project.yml:22 github-token: ${  
secrets.MEDPLUM_BOT_GITHUB_ACCESS_TOKEN }  
.github/workflows/add-issue-to-project.yml:26 github-token: ${  
secrets.MEDPLUM_BOT_GITHUB_ACCESS_TOKEN }  
.github/workflows/assign-pull-request.yml:7 permissions:  
.github/workflows/assign-pull-request.yml:14 permissions:  
.github/workflows/autofix-ci.yml:11 permissions:
```

FINDING

Does the system implement technical policies and procedures for electronic information systems that maintain electronic Protected Health Information to allow access only to those persons or software programs that have been granted access rights as specified in 45 CFR §164.312(a)(1)?

REMEDIATION

The development team must implement and document technical access controls that explicitly restrict access to ePHI based on granted access rights. This includes implementing role-based access controls, user authentication mechanisms, and authorization checks within the FHIR access policy module. The OAuth implementation should be configured to enforce granular permissions, and access control policies must be clearly defined and implemented in the accesspolicy.ts file. Additionally, technical documentation demonstrating how these controls prevent unauthorized access to ePHI should be created and maintained.

HIPAA-005

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:22  timeout-minutes: 45
.github/workflows/build-agent.yml:214  timeout-minutes: 45
.github/workflows/build-agent.yml:296  timeout-minutes: 45
.github/workflows/build-agent.yml:378  timeout-minutes: 45
.github/workflows/build-deb.yml:19  timeout-minutes: 45
.github/workflows/build-helm-charts.yml:19  timeout-minutes: 45
.github/workflows/build.yml:21  timeout-minutes: 45
.github/workflows/build.yml:79  timeout-minutes: 20
```

FINDING

Does the system implement electronic procedures that terminate an electronic session after a predetermined time of inactivity, as required for PHI-accessing interfaces under the HIPAA Security Rule?

REMEDIATION

Implement automatic session timeout functionality for all user-facing applications that access PHI. This should include configurable inactivity timeouts (typically 15-30 minutes for healthcare applications), automatic session termination when timeouts are reached, and proper session state cleanup. Add session timeout configuration to authentication components, middleware, or application settings, and ensure the timeout values are appropriate for healthcare workflows while meeting HIPAA requirements.

HIPAA-006

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
.vscode/settings.json:24  "cSpell.words": ["auditevent", "bullmq",  
"FHIR", "Fhircast", "Medplum"]  
SECURITY.md:7  Medplum uses enterprise-grade security and regular  
audits to ensure you're always protected. We unde  
SECURITY.md:24  - Third-Party Audits - Our organization undergoes  
independent third-party assessments to test our se  
charts/templates/backendconfig.yaml:23  logging:  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:70  
const auditEventCount = counts['AuditEvent'] || 0;  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:71  
const totalResourcesMinusAuditEvent = totalResources -  
auditEventCount;  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:80  
['Counted Resources (total excluding AuditEvent)',  
totalResourcesMinusAuditEvent.toString()],  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:152  
'AuditEvent',
```

FINDING

Does the system implement hardware, software, and procedural mechanisms that record and examine activity in information systems that contain or use electronic Protected Health Information, as required under the audit controls standard?

REMEDIATION

Implement comprehensive audit logging that captures all PHI access, creation, modification, and deletion events. This should include detailed audit trails with user identification, timestamps, data accessed, and actions performed. Enhance the existing AuditEvent framework to automatically log all FHIR resource interactions involving PHI. Add audit log review procedures and automated monitoring capabilities. Document the complete audit control implementation including hardware, software, and procedural mechanisms as required by the standard.

HIPAA-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:152  exclude-azure-cli-credential:
true
.github/workflows/build-agent.yml:153  exclude-environment-credential:
true
.github/workflows/build-agent.yml:154  exclude-workload-identity-
credential: true
.github/workflows/build-agent.yml:155  exclude-managed-identity-
credential: true
.github/workflows/build-agent.yml:156  exclude-shared-token-cache-
credential: true
.github/workflows/build-agent.yml:157  exclude-visual-studio-
credential: true
.github/workflows/build-agent.yml:158  exclude-visual-studio-code-
credential: true
.github/workflows/build-agent.yml:159  exclude-azure-powershell-
credential: false
```

FINDING

Does the system limit the Protected Health Information disclosed or accessed to the minimum necessary to accomplish the intended purpose, consistent with the minimum necessary standard under the Privacy Rule?

REMEDIATION

Implement explicit minimum necessary access controls throughout the system by adding role-based data filtering that restricts PHI queries and responses based on user permissions and purpose of use. Add audit logging for all PHI access attempts with justification tracking. Enhance the existing FHIRPath filtering functions to automatically apply minimum necessary restrictions based on the requesting user's role and the specific healthcare workflow context. Document and enforce policies that define what constitutes "minimum necessary" for each user role and use case, then implement these as enforceable technical controls in the API layer.

HIPAA-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:41 - examples/medplum-photon-integration/src/**/*
.github/labeler.yml:43 integration:
.github/workflows/build-agent.yml:31 id-token: write # Required for
OIDC authentication with Azure Trusted Signing
.github/workflows/build-agent.yml:137 - name: Login to Azure
.github/workflows/build-agent.yml:139 uses:
azure/login@a457da9ea143d694b1b9c7c869ebb04ebe844ef5 # v2.3.0
.github/workflows/build-agent.yml:141 client-id: ${
secrets.AZURE_CLIENT_ID }}
.github/workflows/build-agent.yml:142 tenant-id: ${
secrets.AZURE_TENANT_ID }}
.github/workflows/build-agent.yml:143 subscription-id: ${
secrets.AZURE_SUBSCRIPTION_ID }}
```

FINDING

Does the system integrate with third-party services that may receive, maintain, or transmit Protected Health Information, and if so, is there evidence that Business Associate Agreement requirements are addressed in the code or configuration?

REMEDATION

Implement documentation and configuration controls that demonstrate BAA compliance for all third-party integrations. This should include: (1) adding configuration files or code comments that reference executed BAAs for each third-party service, (2) implementing runtime checks to ensure only BAA-compliant services can access PHI, (3) creating a registry of approved business associates in the codebase, and (4) adding validation logic that prevents data transmission to services without proper BAA status verification. Consider adding environment variables or configuration flags that explicitly track BAA compliance status for each integration.

HIPAA-009

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/auto_assign.yml:9 - mattlong
.github/workflows/build.yml:383 retention-days: 30
.github/workflows/scorecard.yml:73 retention-days: 5
Dockerfile:7 # The archive files are decompressed and extracted into
the specified destinations.
Dockerfile:9 # See:
https://docs.docker.com/reference/dockerfile/#adding-local-tar-
archives
biome.json:50 "noDelete": "warn"
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1298
display: 'I could use a little more help',
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:2073
display: 'Little interest or pleasure in doing things?'
```

FINDING

Does the system implement policies and procedures to address the final disposition of electronic Protected Health Information and the hardware or electronic media on which it is stored, as well as removal of PHI before media is available for reuse?

REMEDIATION

Implement comprehensive data retention and disposal policies that specifically address PHI lifecycle management. Create documented procedures for secure deletion of PHI from all storage media, including databases, backups, and temporary files. Establish secure media sanitization protocols before hardware reuse or disposal, with verification procedures. Add audit logging for all PHI deletion operations and implement automated retention enforcement mechanisms that comply with required retention periods before secure disposal.

HIPAA-010

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:65  restore-keys: |  
.github/workflows/build-agent.yml:240 restore-keys: |  
.github/workflows/build-agent.yml:322 restore-keys: |  
.github/workflows/build-agent.yml:404 restore-keys: |  
.github/workflows/build.yml:47  restore-keys: |  
.github/workflows/build.yml:101  restore-keys: |  
.github/workflows/build.yml:209  restore-keys: |  
.github/workflows/build.yml:311  restore-keys: |
```

FINDING

Does the system implement procedures for detecting, reporting, and responding to suspected or known security incidents involving electronic Protected Health Information, and does it provide for emergency access to PHI during system disruptions?

REMEDIATION

Implement a comprehensive security incident detection and response system that includes automated monitoring for suspicious activities involving PHI, incident logging mechanisms, notification procedures for security breaches, and documented response workflows. Additionally, establish emergency access procedures that allow authorized personnel to access PHI during system outages or disruptions while maintaining audit trails. This should include backup authentication methods, emergency user provisioning processes, and clear documentation of when and how emergency access can be invoked.

PCI-DSS

10 findings

PCI SSC · Fines \$5K-\$100K/month

PCIDSS-001

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/scorecard.yml:52 # repo_token: ${{
secrets.SCORECARD_TOKEN }}
charts/templates/_helpers.tpl:2 Expand the name of the chart.
charts/templates/_helpers.tpl:17 We truncate at 63 chars because some
Kubernetes name fields are limited to this (by the DNS naming s
examples/foomedical/src/Router.tsx:6 import { MembershipAndBilling }
from './pages/account/MembershipAndBilling';
examples/foomedical/src/Router.tsx:66 <Route path="membership-and-
billing" element={<MembershipAndBilling />} />
examples/foomedical/src/components/SideMenu.tsx:29 <span>{item.name}
</span>
examples/foomedical/src/components/SideMenu.tsx:34 <span>
{subItem.name}</span>
```

FINDING

Does this system store, process, or transmit cardholder data including primary account numbers (PAN), and if so, are adequate protections in place to render stored PAN unreadable, as required under PCI DSS Requirement 3.5?

REMEDIATION

The development team must implement adequate PAN protection controls before any cardholder data storage occurs. This requires: (1) implementing strong cryptographic methods to render any stored PAN unreadable (encryption with proper key management, irreversible hashes with strong cryptographic functions, or tokenization), (2) ensuring PAN is never stored in clear text anywhere in the system, (3) documenting the specific protection methods used, and (4) conducting a comprehensive code review to verify no PAN storage exists without proper protection. If PAN storage is not actually required for business operations, consider eliminating storage entirely and using payment processor tokens instead.

PCIDSS-002

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/CODEOWNERS:2 # See:
https://docs.github.com/en/repositories/managing-your-repositorys-
settings-and-features/custo
.github/workflows/add-issue-to-project.yml:21 project-url:
https://github.com/orgs/medplum/projects/1
.github/workflows/add-issue-to-project.yml:25 project-url:
https://github.com/orgs/medplum/projects/3
.github/workflows/build-agent.yml:50 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:52 # See:
https://github.com/actions/cache/blob/cdf6c1fa76f9f475f3d7449005a359c84ca
.github/workflows/build-agent.yml:93 * Taken from
https://github.com/dlemstra/code-sign-action
.github/workflows/build-agent.yml:162 endpoint:
https://eus.codesigning.azure.net/
.github/workflows/build-agent.yml:231 registry-url:
'https://registry.npmjs.org'
```

FINDING

Is cardholder data encrypted using strong cryptography during transmission over open public networks and when stored at rest, consistent with PCI DSS Requirements 3.5 and 4.2?

REMEDIATION

Implement strong encryption for cardholder data at rest using AES-256 or equivalent cryptographic standards, and ensure all cardholder data transmission uses TLS 1.2+ with strong cipher suites. Replace all HTTP endpoints with HTTPS equivalents in configuration files, particularly in docker-compose.full-stack.yml for base URLs and health checks. Update timestamp services in GitHub workflows to use HTTPS instead of HTTP. Document encryption key management procedures and ensure proper cryptographic controls are in place throughout the application stack.

PCIDSS-003

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:24 - packages/server/src/fhir/accesspolicy.ts
.github/workflows/add-issue-to-project.yml:11 permissions:
.github/workflows/assign-pull-request.yml:7 permissions:
.github/workflows/assign-pull-request.yml:14 permissions:
.github/workflows/autofix-ci.yml:11 permissions:
.github/workflows/autofix-ci.yml:17 permissions:
.github/workflows/build-agent.yml:16 permissions:
.github/workflows/build-agent.yml:28 permissions:
```

FINDING

Does the system restrict access to cardholder data to only those individuals and systems whose job requires such access, implementing role-based access controls consistent with PCI DSS Requirement 7?

REMEDIATION

Implement comprehensive role-based access controls that specifically restrict cardholder data access to only authorized personnel based on job function requirements. This should include documented access policies, user role definitions tied to business needs, regular access reviews, and technical controls that enforce these restrictions at the application and data layers. The existing FHIR access policy should be enhanced to include specific cardholder data protection mechanisms, and all access control implementations should be clearly documented and auditable.

PCIDSS-004

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
README.md:115 Thanks to [Chromatic](https://www.chromatic.com/) for
providing the visual testing platform that hel
charts/templates/backendconfig.yaml:1  {{- if and (eq
.Values.global.cloudProvider "gcp") (eq .Values.ingress.deploy true)
}}
charts/templates/backendconfig.yaml:11  name: ingress-security-policy
charts/templates/frontendconfig.yaml:1  {{- if and (eq
.Values.global.cloudProvider "gcp") (eq .Values.ingress.deploy true)
}}
charts/templates/ingress.yaml:1  {{- if and (eq
.Values.global.cloudProvider "gcp") (eq .Values.ingress.deploy true)
}}
charts/templates/ingress.yaml:3  kind: Ingress
charts/templates/ingress.yaml:10  ingressClassName: "gce"
charts/templates/ingress.yaml:11  kubernetes.io/ingress.global-static-
ip-name: medplum-external-ip
```

FINDING

Does the system implement network segmentation to isolate the cardholder data environment (CDE) from other network segments, reducing the scope of PCI DSS compliance as described in Requirement 1?

REMEDIATION

Implement dedicated network segmentation controls to create a clearly defined CDE boundary. This should include configuring network security groups, VPC isolation, subnet segregation, and firewall rules that restrict traffic flow between the CDE and other network segments. Document the network topology showing segmented zones, implement ingress/egress filtering rules, and ensure that only authorized systems can communicate with the CDE. Consider using Kubernetes network policies, cloud provider security groups, and dedicated VPCs/VNets to achieve proper isolation.

PCIDSS-005

PATTERN OF CONCERN

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:8 workflow_dispatch:
.github/workflows/build-agent.yml:115 console.warn('Skipping %s due
to error.', signtoolFilename);
.github/workflows/build-deb.yml:11 workflow_dispatch:
.github/workflows/build-deb.yml:81 --gpg-options="--passphrase-fd 0 -
-pinentry-mode loopback" \
.github/workflows/build-helm-charts.yml:11 workflow_dispatch:
.github/workflows/build.yml:251 uses: SonarSource/sonarqube-scan-
action@01850e2590cc09ed26831056406ae1525aa41ad5 # master
.github/workflows/build.yml:187 --health-cmd "redis-cli ping"
.github/workflows/build.yml:289 --health-cmd "redis-cli ping"
```

FINDING

Does the system demonstrate evidence of vulnerability management practices including regular patching, dependency updates, and vulnerability scanning, consistent with PCI DSS Requirement 6?

REMEDIATION

Implement a comprehensive vulnerability management program by adding automated dependency scanning tools (like Dependabot or Snyk) to GitHub workflows, establish regular vulnerability scanning schedules beyond the current SonarQube integration, create automated patch management workflows for both application dependencies and system components, and document vulnerability remediation timelines and procedures. Consider adding security-focused workflow triggers and dependency update automation to ensure continuous compliance with PCI DSS vulnerability management requirements.

PCIDSS-006

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/autofix-ci.yml:28 - run: npm run lint:fix
.github/workflows/build.yml:76  eslint:
.github/workflows/build.yml:77  name: Run eslint
.github/workflows/build.yml:84  eslint_errs: ${
steps.fmt.outputs.eslint_errs }}
.github/workflows/build.yml:106 name: Install eslint
.github/workflows/build.yml:121 - name: Run eslint
.github/workflows/build.yml:125 npm run lint 2> eslint.err >
eslint1.err || echo 'failed' > .failed
.github/workflows/build.yml:129 echo "eslint_errs<<${delimiter}" >>
"${GITHUB_OUTPUT}"
```

FINDING

Does the system implement security testing controls including code review, static analysis, and penetration testing practices, as required under PCI DSS Requirement 6.3 and 11.4?

REMEDIATION

Implement comprehensive security testing controls including: (1) Add security-focused static analysis tools like CodeQL, Semgrep, or Snyk to CI/CD pipelines beyond basic ESLint; (2) Establish documented penetration testing procedures and schedule regular assessments; (3) Address security anti-patterns by replacing `exec()` calls in `packages/agent/src/app.ts:67` and `packages/cli/src/auth.ts:120` with safer alternatives, and reviewing `eval()` usage in `packages/core/src/fhirlexer/parse.ts`; (4) Implement formal code review processes that specifically check for security vulnerabilities before deployment.

PCIDSS-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.vscode/settings.json:24  "cSpell.words": ["auditevent", "bullmq",  
"FHIR", "Fhircast", "Medplum"]  
SECURITY.md:7  Medplum uses enterprise-grade security and regular  
audits to ensure you're always protected. We unde  
SECURITY.md:24  - Third-Party Audits - Our organization undergoes  
independent third-party assessments to test our se  
charts/templates/backendconfig.yaml:23  logging:  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:70  
const auditEventCount = counts['AuditEvent'] || 0;  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:71  
const totalResourcesMinusAuditEvent = totalResources -  
auditEventCount;  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:80  
['Counted Resources (total excluding AuditEvent)',  
totalResourcesMinusAuditEvent.toString()],  
examples/medplum-demo-bots/src/resource-usage/resource-usage.ts:152  
'AuditEvent',
```

FINDING

Does the system implement audit trail mechanisms that record all individual access to cardholder data, all actions taken by any individual with root or administrative privileges, and all access to audit trails, as required under PCI DSS Requirement 10?

REMEDIATION

Implement comprehensive audit logging that captures: (1) all individual access attempts to cardholder data with user identification, timestamps, and data elements accessed; (2) all actions performed by users with root or administrative privileges including login attempts, configuration changes, and system modifications; and (3) all access to audit logs themselves including who viewed, modified, or deleted audit records. Configure automated log generation that cannot be disabled by users, ensure logs are stored securely with integrity protection, and establish real-time monitoring for suspicious access patterns.

PCIDSS-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
charts/values.yaml:12 # type: "azure:keyVaultURL:secretName"
examples/medplum-photon-integration/photon-webhook.png:430
qC%M 27']I)0\ 0;ŠsEcIJ :3\_1p Nn mzfU + ^ziV;|V01' 1d0^)^r 9 [9'tv)
{f zŸ o U; // %DEkl~7r0c@f
examples/medplum-photon-integration/photon-webhook.png:1466
i0w&b_r k(4 gr R }im? x)] , a{ DB > Z
examples/medplum-
provider/src/components/ChargeItem/ChargeItemPanel.tsx:77 const
cptCodeKey =
`cpt-${chargeItem.id}-${JSON.stringify(cptCodes?.coding)}`;
examples/medplum-
provider/src/components/ChargeItem/ChargeItemPanel.tsx:86 key=
{cptCodeKey}
examples/medplum-smart-on-fhir-demo/src/pages/LaunchPage.tsx:37 async
function fetchSmartConfiguration(iss: string):
Promise<SmartConfiguration> {
```

FINDING

Does the system implement cryptographic key management procedures including key generation, distribution, storage, rotation, and destruction, consistent with PCI DSS Requirement 3.6 and 3.7?

REMEDIATION

Implement comprehensive cryptographic key management procedures including automated key generation, secure distribution mechanisms, encrypted storage with proper access controls, scheduled rotation policies, and secure destruction processes. Remove all hardcoded keys and secrets from source code and migrate to a proper secrets management system (the Azure Key Vault reference in charts/values.yaml:12 suggests infrastructure exists but implementation is incomplete). Establish formal key management policies documenting the entire key lifecycle, implement proper key escrow procedures, and ensure all cryptographic

operations follow documented procedures with audit trails for key management activities.

PCIDSS-009

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:41 - examples/medplum-photon-integration/src/**/*
.github/labeler.yml:43 integration:
.github/workflows/autofix-ci.yml:21 - uses:
actions/checkout@8e8c483db84b4bee98b60c0593521ed34d9990e8 # v6.0.1
.github/workflows/build-agent.yml:33 - name: Checkout repository
.github/workflows/build-agent.yml:34 uses:
actions/checkout@8e8c483db84b4bee98b60c0593521ed34d9990e8 # v6.0.1
.github/workflows/build-agent.yml:224 - name: Checkout repository
.github/workflows/build-agent.yml:225 uses:
actions/checkout@8e8c483db84b4bee98b60c0593521ed34d9990e8 # v6.0.1
.github/workflows/build-agent.yml:306 - name: Checkout repository
```

FINDING

Does the system manage third-party service providers that have access to cardholder data with appropriate controls, agreements, and monitoring, consistent with PCI DSS Requirement 12.8?

REMEDIATION

Implement a comprehensive third-party service provider management program that includes: documented agreements with all service providers that handle cardholder data (including cloud services, CI/CD platforms, and monitoring tools), regular security assessments of these providers, contractual requirements for PCI DSS compliance where applicable, and ongoing monitoring of third-party access to cardholder data environments. Create a formal vendor inventory and risk assessment process, and ensure all third-party integrations include appropriate security controls and audit trails.

PCIDSS-010

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
LICENSE.txt:158  incidental, or consequential damages of any character
arising as a
README.md:1  # [Medplum](https://www.medplum.com) &middot; [![GitHub
license](https://img.shields.io/badge/licens
SECURITY.md:14  - Continuous Monitoring - Independent third-party
penetration, threat, and vulnerability testing.
SECURITY.md:27  - Continuous Monitoring - We continuously monitor our
security and compliance status to ensure there
charts/values.yaml:55  allowPrivilegeEscalation: false
examples/foomedical/README.md:11  <img
src="https://sonarcloud.io/api/project_badges/measure?
project=medplum_foomedical&metric=alert_s
examples/foomedical/package.json:25  "@mantine/notifications":
"8.3.18",
examples/foomedical/src/main.tsx:5  import { Notifications } from
'@mantine/notifications';
```

FINDING

Does the system implement an incident response plan that addresses suspected or confirmed cardholder data breaches, including detection, containment, and notification procedures, as required under PCI DSS Requirement 12.10?

REMEDIATION

The organization must develop and document a comprehensive incident response plan that specifically addresses cardholder data breach scenarios. This plan should include detailed procedures for breach detection (automated monitoring, alerting mechanisms), containment steps (isolation of affected systems, access controls), and notification requirements (timelines for notifying card brands, acquirers, and relevant parties). The plan should be documented in the repository's security documentation and include clear escalation paths, roles and responsibilities, and communication templates for breach scenarios.

SOC2

10 findings

AICPA · Loss of enterprise contracts

SOC2-001

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:22 - packages/server/src/oauth/**/*
.github/workflows/add-issue-to-project.yml:22 github-token: ${
secrets.MEDPLUM_BOT_GITHUB_ACCESS_TOKEN }}
.github/workflows/add-issue-to-project.yml:26 github-token: ${
secrets.MEDPLUM_BOT_GITHUB_ACCESS_TOKEN }}
.github/workflows/build-agent.yml:31 id-token: write # Required for
OIDC authentication with Azure Trusted Signing
.github/workflows/build-agent.yml:137 - name: Login to Azure
.github/workflows/build-agent.yml:139 uses:
azure/login@a457da9ea143d694b1b9c7c869ebb04ebe844ef5 # v2.3.0
.github/workflows/build-agent.yml:31 id-token: write # Required for
OIDC authentication with Azure Trusted Signing
.github/workflows/build-agent.yml:146 - name: Sign executables with
Azure Trusted Signing
```

FINDING

Does the system implement logical access security controls over user authentication that are suitably designed and operating effectively to restrict access to authorized users, consistent with the Common Criteria CC6.1 requirement for logical and physical access controls?

REMEDIATION

The development team needs to provide evidence of implemented user authentication controls including: authentication middleware or handlers, user session management, access control lists or role-based permissions, password policies, multi-factor authentication capabilities, and login/logout functionality. Code files should demonstrate how the system validates user credentials, manages user sessions, and enforces access restrictions. Documentation of the OAuth/OpenID implementation mentioned in the README should be accompanied by actual source code that shows these authentication mechanisms are properly implemented and configured.

SOC2-002

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:24 - packages/server/src/fhir/accesspolicy.ts
.github/workflows/add-issue-to-project.yml:11 permissions:
.github/workflows/assign-pull-request.yml:7 permissions:
.github/workflows/assign-pull-request.yml:14 permissions:
.github/workflows/autofix-ci.yml:11 permissions:
.github/workflows/autofix-ci.yml:17 permissions:
.github/workflows/build-agent.yml:16 permissions:
.github/workflows/build-agent.yml:28 permissions:
```

FINDING

Does the system implement role-based or attribute-based access controls that restrict system functions and data access based on authorized user roles, consistent with the principle of least privilege as required under CC6.3?

REMEDIATION

The development team should provide detailed documentation and code review of the FHIR access policy implementation to demonstrate how user roles are defined, how permissions are mapped to specific system functions and data access, and how the principle of least privilege is enforced throughout the application. Additionally, expand access control implementation beyond GitHub workflows to cover all application components, ensuring that each user role has only the minimum permissions necessary to perform their authorized functions.

SOC2-003

PATTERN OF CONCERN

REGULATORY STANDARD

EVIDENCE

```
.github/CODEOWNERS:2 # See:
https://docs.github.com/en/repositories/managing-your-repositorys-
settings-and-features/custo
.github/workflows/add-issue-to-project.yml:21 project-url:
https://github.com/orgs/medplum/projects/1
.github/workflows/add-issue-to-project.yml:25 project-url:
https://github.com/orgs/medplum/projects/3
.github/workflows/build-agent.yml:50 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:52 # See:
https://github.com/actions/cache/blob/cdf6c1fa76f9f475f3d7449005a359c84ca
.github/workflows/build-agent.yml:93 * Taken from
https://github.com/dlemstra/code-sign-action
.github/workflows/build-agent.yml:162 endpoint:
https://eus.codesigning.azure.net/
.github/workflows/build-agent.yml:231 registry-url:
'https://registry.npmjs.org'
```

FINDING

Does the system protect data during transmission over networks using encryption or other equivalent security measures, consistent with the CC6.7 requirement for protection of information during transmission?

REMEDIATION

Replace all HTTP endpoints with HTTPS equivalents, particularly the Microsoft timestamp service URLs in the code signing workflows and the localhost healthcheck endpoints in development configurations. Update docker-compose configurations to use HTTPS for all base URLs, even in development environments, or clearly document that these are development-only configurations that should never be used in production. Consider implementing TLS termination at the container level for consistent encryption across all environments.

SOC2-004

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.vscode/settings.json:24  "cSpell.words": ["auditevent", "bullmq",  
"FHIR", "Fhircast", "Medplum"]  
README.md:1  # [Medplum](https://www.medplum.com) &middot; [![GitHub  
license](https://img.shields.io/badge/licens  
README.md:1  # [Medplum](https://www.medplum.com) &middot; [![GitHub  
license](https://img.shields.io/badge/licens  
SECURITY.md:7  Medplum uses enterprise-grade security and regular  
audits to ensure you're always protected. We unde  
SECURITY.md:24  - Third-Party Audits - Our organization undergoes  
independent third-party assessments to test our se  
SECURITY.md:14  - Continuous Monitoring - Independent third-party  
penetration, threat, and vulnerability testing.  
SECURITY.md:27  - Continuous Monitoring - We continuously monitor our  
security and compliance status to ensure there  
SECURITY.md:14  - Continuous Monitoring - Independent third-party  
penetration, threat, and vulnerability testing.
```

FINDING

Does the system implement logging, monitoring, and alerting mechanisms that detect and record security events, anomalies, and unauthorized activities, as required under CC7.2 for monitoring system components for anomalies?

REMEDIATION

Implement comprehensive security event logging throughout the application, including audit trails for authentication, authorization, data access, and system changes. Add monitoring services that can detect anomalous behavior patterns, unauthorized access attempts, and security-relevant system events. Configure alerting mechanisms that notify security personnel of potential incidents in real-time. Ensure all security events are logged with sufficient detail (timestamps, user identification, actions performed, resources accessed) and stored in a centralized,

tamper-evident logging system that supports compliance reporting and incident investigation.

SOC2-005

PATTERN OF CONCERN

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:1 dependencies:
.github/labeler.yml:23 - packages/server/src/scim/**/*
.github/labeler.yml:46 - packages/ccda/src/**/*
.github/labeler.yml:58 - packages/ccda/src/**/*
.github/labeler.yml:69 - packages/cdk/src/**/*
.github/labeler.yml:71 - terraform/**/*
.github/workflows/add-issue-to-project.yml:19 - uses: actions/add-to-
project@31b3f3ccdc584546fc445612dec3f38ff5edb41c # v0.5.0
.github/workflows/add-issue-to-project.yml:23 - uses: actions/add-to-
project@31b3f3ccdc584546fc445612dec3f38ff5edb41c # v0.5.0
```

FINDING

Does the system demonstrate evidence of change management controls including version control, code review processes, and controlled deployment procedures, as required under CC8.1 for managing changes to infrastructure, data, software, and procedures?

REMEDIATION

Implement and document mandatory code review processes with required approvals before merging changes. Add branch protection rules requiring pull request reviews and status checks. Establish clear deployment approval workflows with evidence of authorized personnel sign-offs for production deployments. Document change management procedures covering infrastructure, data, software, and procedural changes with appropriate approval matrices and audit trails.

SOC2-006

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
LICENSE.txt:158  incidental, or consequential damages of any character
arising as a
README.md:1  # [Medplum](https://www.medplum.com) &middot; [![GitHub
license](https://img.shields.io/badge/licens
SECURITY.md:64  However, we believe in recognizing and rewarding
valuable security research. For novel, verifiable v
charts/values.yaml:55  allowPrivilegeEscalation: false
examples/foomedical/README.md:11  }>
examples/foomedical/src/pages/GetCarePage.tsx:72  </Alert>
```

FINDING

Does the system implement incident detection, response, and recovery procedures that enable timely identification and remediation of security incidents, consistent with CC7.3 requirements for evaluating security events and CC7.4 for responding to identified incidents?

REMEDIATION

Implement comprehensive incident response capabilities including: automated security event detection and logging systems, formal incident classification and escalation procedures, documented response workflows with defined roles and responsibilities, incident tracking and case management systems, and recovery procedures with defined RTO/RPO objectives. Additionally, establish security event monitoring dashboards, alerting mechanisms for security incidents, and regular testing of incident response procedures to ensure timely identification and remediation of security events.

SOC2-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.gitattributes:23 package-lock.json -diff
.gitattributes:24 package-lock.json linguist-generated=true
.github/labeler.yml:3 - any-glob-to-any-file: 'package-lock.json'
.github/workflows/build-agent.yml:204 echo "MEDPLUM_VERSION=$(node -p
"require('./package.json').version)" >> $GITHUB_ENV
.github/workflows/build-agent.yml:274 echo "MEDPLUM_VERSION=$(node -p
"require('./package.json').version)" >> $GITHUB_ENV
.github/workflows/build-agent.yml:356 echo "MEDPLUM_VERSION=$(node -p
"require('./package.json').version)" >> $GITHUB_ENV
.github/workflows/build-agent.yml:438 echo "MEDPLUM_VERSION=$(node -p
"require('./package.json').version)" >> $GITHUB_ENV
.github/workflows/build-agent.yml:64 key: ${ runner.os }-build-
agent-${ env.cache-name }-${ hashFiles('**/package-lock.json' ) }
```

FINDING

Does the system assess and manage risks associated with third-party vendors, libraries, and service providers, including dependency vulnerability management, consistent with CC9.2 requirements for risk assessment of third-party service providers?

REMEDIATION

Implement a comprehensive third-party risk management program including: automated dependency vulnerability scanning tools integrated into CI/CD pipelines, documented vendor risk assessment procedures for all service providers, regular security assessments of critical dependencies, and establishment of criteria for evaluating and monitoring third-party risks. Add dependency check workflows to GitHub Actions that fail builds on high-severity vulnerabilities, maintain an inventory of all third-party services with associated risk ratings, and create formal vendor management policies that address security requirements and ongoing monitoring obligations.

SOC2-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/auto_assign.yml:11 - ThatOneBro  
.github/labeler.yml:2 - changed-files:  
.github/labeler.yml:6 - changed-files:  
.github/labeler.yml:13 - changed-files:  
.github/labeler.yml:19 - changed-files:  
.github/labeler.yml:28 - changed-files:  
.github/labeler.yml:33 - changed-files:  
.github/labeler.yml:39 - changed-files:
```

FINDING

Does the system implement data backup, replication, and recovery controls that ensure availability and recoverability of data, consistent with the A1.2 criterion for recovery of infrastructure and data to meet objectives?

REMEDIATION

Implement comprehensive data backup and recovery controls including: automated backup schedules for all critical data stores, database replication configurations, disaster recovery runbooks, backup verification procedures, and recovery time/point objectives (RTO/RPO) documentation. Add infrastructure-as-code configurations that define backup policies, cross-region replication for critical systems, and automated recovery testing procedures. Document these controls in your repository with clear procedures for data recovery scenarios.

SOC2-009

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-deb.yml:56  uses: ruby/setup-  
ruby@cf7216d52fba1017929b4d7162fabe2b30af5b49 # v1.262.0  
charts/templates/deployment.yaml:46  imagePullPolicy: IfNotPresent  
examples/medplum-demo-bots/src/vital/vital.test.ts:260  id: '42fa4b3b-  
0b3b-4b3b-8b3b-2b3b3b3b3b3b',  
examples/medplum-  
provider/src/components/pharmacy/DoseSpotPharmacyDialog.tsx:4  import  
{ useDoseSpotPharmacySearch } from '@medplum/dosespot-react';  
examples/medplum-  
provider/src/components/pharmacy/DoseSpotPharmacyDialog.tsx:16  export  
function DoseSpotPharmacyDialog(props: PharmacyDialogBaseProps):  
JSX.Element {
```

FINDING

Does the system implement or support multi-factor authentication for user access, particularly for privileged accounts and administrative interfaces, consistent with CC6.1 requirements for logical access security?

REMEDIATION

Implement multi-factor authentication controls throughout the system, especially for administrative and privileged accounts. This should include configuring MFA in the authentication service, adding MFA enforcement in deployment configurations, implementing MFA requirements in the OAuth/OpenID authentication flows mentioned in the documentation, and ensuring all administrative interfaces require second-factor authentication. Documentation and configuration files should clearly demonstrate MFA implementation and enforcement policies.

SOC2-010

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
README.md:17 - [Contributing](#contributing)
README.md:23 ## Contributing
README.md:28 limited scope -- it's our entire product. Our
[Contributing documentation](https://medplum.com/docs/
README.md:49 Did you learn how to do something using Medplum that
wasn't obvious on your first try? By contributi
README.md:67 **Ready to get started writing code?** Follow the [local
setup instructions](https://www.medplum.com
packages/app/README.md:44 For more information, refer to the
[Developer Instructions](https://www.medplum.com/docs/contributin
packages/cdk/README.md:16 See [Developer Setup]
(https://www.medplum.com/docs/contributing) for cloning the repository
and inst
packages/docs/blog/2025-05-15-so-youre-thinking-about-forking.md:31 |
**Talent attraction** | Engineers prefer contributing to widely-used
projects; recruiting for a
```

FINDING

Does the system demonstrate evidence of documented security policies, including acceptable use, data classification, and access management policies, as required under CC1.1 for the entity's commitment to integrity and ethical values?

REMEDIATION

The organization needs to create and document formal security policies covering acceptable use of systems and data, data classification standards, and access management procedures. These policies should be stored in accessible locations within the repository (such as a dedicated security or policies directory) and referenced in the main README.md. The policies must go beyond development practices to address organizational security governance, user responsibilities, data handling requirements, and access control principles that demonstrate the entity's commitment to integrity and ethical values as required by the trust services criteria.

SOX

8 findings

SEC / PCAOB · Criminal penalties, delisting

SOX-001

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/publish-meta.yml:63 # Check if asset already exists
in S3 (idempotent check)
docker-compose.full-stack.yml:18 -
'default_transaction_isolation=REPEATABLE READ'
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1062
code: 'financialStrain',
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1063
display: 'Financial Strain',
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1067
linkId: '/supplementalQuestions/financialStrain',
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1068
text: 'Financial Strain',
examples/foomedical/src/pages/ScreeningQuestionnairePage.tsx:1096
linkId: '/supplementalQuestions/financialStrain/11',
examples/medplum-chat-demo/data/example/example-data.json:2602
"display": "Anatomic pathologist (occupation)"
```

FINDING

Does the system implement controls to ensure the integrity, accuracy, and completeness of financial data and transactions, consistent with SOX Section 302 requirements for management certification of financial statements?

REMEDIATION

Implement comprehensive financial data integrity controls including: automated validation rules for financial transactions, audit logging for all financial data modifications, role-based access controls for financial systems, data completeness checks, reconciliation processes, and automated testing of financial calculation accuracy. Additionally, establish documented procedures for financial data governance, implement change management controls for financial reporting systems, and create monitoring dashboards to track data integrity metrics that support SOX 302 management certification requirements.

SOX-002

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/add-issue-to-project.yml:11 permissions:
.github/workflows/assign-pull-request.yml:7 permissions:
.github/workflows/assign-pull-request.yml:14 permissions:
.github/workflows/autofix-ci.yml:11 permissions:
.github/workflows/autofix-ci.yml:17 permissions:
.github/workflows/build-agent.yml:16 permissions:
.github/workflows/build-agent.yml:28 permissions:
.github/workflows/build-agent.yml:220 permissions:
```

FINDING

Does the system implement access controls that restrict access to financial systems and data to authorized personnel, with appropriate authentication and authorization mechanisms, as required under SOX Section 404 internal controls?

REMEDIATION

Implement proper financial system access controls including: role-based access control (RBAC) configurations that specifically restrict financial data access, multi-factor authentication requirements for financial system users, documented authorization matrices showing who can access what financial data, audit logging of all financial system access attempts, and segregation of duties controls that prevent unauthorized financial data manipulation. These controls should be coded into the application layer, not just the CI/CD pipeline level.

SOX-003

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:168 timestamp-rfc3161:
http://timestamp.acs.microsoft.com
.github/workflows/build-agent.yml:169 timestamp-digest: SHA256
.github/workflows/publish-meta.yml:72 --cache-control "public, max-
age=31536000, immutable"
.github/workflows/publish.yml:294 timestamp-rfc3161:
http://timestamp.acs.microsoft.com
.github/workflows/publish.yml:295 timestamp-digest: SHA256
.vscode/settings.json:24 "cSpell.words": ["auditevent", "bullmq",
"FHIR", "Fhircast", "Medplum"]
SECURITY.md:7 Medplum uses enterprise-grade security and regular
audits to ensure you're always protected. We unde
SECURITY.md:24 - Third-Party Audits - Our organization undergoes
independent third-party assessments to test our se
```

FINDING

Does the system maintain a complete and tamper-evident audit trail of all financial transactions, modifications, and access events, sufficient to support the audit requirements under SOX Section 802?

REMEDIATION

Implement a complete audit logging system that captures all financial transactions, data modifications, and user access events with tamper-evident controls. This should include cryptographic integrity protection, immutable log storage, detailed transaction metadata (user, timestamp, before/after values), and retention policies that meet SOX requirements. Ensure the audit system covers all financial data flows, not just the code deployment timestamping that currently exists.

SOX-004

MEDIUM RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:1 dependencies:
.github/labeler.yml:23 - packages/server/src/scim/**/*
.github/labeler.yml:46 - packages/ccda/src/**/*
.github/labeler.yml:58 - packages/ccda/src/**/*
.github/labeler.yml:69 - packages/cdk/src/**/*
.github/workflows/add-issue-to-project.yml:19 - uses: actions/add-to-
project@31b3f3ccdc584546fc445612dec3f38ff5edb41c # v0.5.0
.github/workflows/add-issue-to-project.yml:23 - uses: actions/add-to-
project@31b3f3ccdc584546fc445612dec3f38ff5edb41c # v0.5.0
.github/workflows/add-issue-to-project.yml:7 pull_request_target:
```

FINDING

Does the system implement change management controls for software that processes financial data, including version control, code review, testing, and controlled deployment, consistent with SOX IT general controls?

REMEDIATION

Implement and document formal change management procedures including: mandatory code review requirements through GitHub branch protection rules, automated testing workflows that must pass before deployment, formal approval processes for production deployments, and clear separation of duties between development and production environments. Add documentation describing the complete software development lifecycle process, testing requirements, and deployment controls to demonstrate compliance with SOX Section 404 IT general controls for change management.

SOX-005

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:8  workflow_dispatch:
.github/workflows/build-deb.yml:11  workflow_dispatch:
.github/workflows/build-helm-charts.yml:11  workflow_dispatch:
.github/workflows/build.yml:3  # see
https://docs.github.com/en/actions/using-workflows/workflow-syntax-
for-github-actions#concurr
.github/workflows/build.yml:2  # Limit a single job to run at a time
for a given branch/PR to save resources and speed up CI
.github/workflows/build.yml:128  delimiter="$(openssl rand -hex 8)"
.github/workflows/build.yml:129  echo "eslint_errs<<${delimiter}" >>
"${GITHUB_OUTPUT}"
.github/workflows/build.yml:132  echo "${delimiter}" >>
"${GITHUB_OUTPUT}"
```

FINDING

Does the system implement segregation of duties controls that prevent any single individual from having the ability to both authorize and execute financial transactions, or to both develop and deploy changes to financial systems?

REMEDIATION

Implement branch protection rules requiring pull request approvals from different individuals than the code author. Add required reviewers for deployment workflows, particularly for the deploy.yml workflow. Remove or restrict workflow_dispatch triggers for production deployments, replacing them with approval-gated processes. Implement role-based access controls in GitHub that separate development permissions from deployment permissions, ensuring no single user can both commit code and execute production deployments.

SOX-006

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-deb.yml:79 --preserve-versions \  
.github/workflows/build.yml:383 retention-days: 30  
.github/workflows/publish-meta.yml:72 --cache-control "public, max-  
age=31536000, immutable"  
.github/workflows/scorecard.yml:73 retention-days: 5  
Dockerfile:7 # The archive files are decompressed and extracted into  
the specified destinations.  
Dockerfile:9 # See:  
https://docs.docker.com/reference/dockerfile/#adding-local-tar-  
archives  
Dockerfile:8 # We do this to preserve the folder structure in a  
single layer.  
charts/.helmignore:13 # Common backup files
```

FINDING

Does the system implement data retention policies that preserve financial records, audit work papers, and supporting documentation for the minimum retention period required under SOX Section 802 (not less than 7 years)?

REMEDIATION

Implement comprehensive data retention policies and technical controls specifically for financial records and audit documentation. This should include database-level retention settings, automated archival processes, and policy documentation that explicitly addresses SOX Section 802 requirements. Configure retention periods of at least 7 years for all financial data, audit logs, and supporting documentation. Consider implementing immutable storage solutions and automated compliance monitoring to ensure ongoing adherence to retention requirements.

SOX-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/labeler.yml:24 - packages/server/src/fhir/accesspolicy.ts
.github/labeler.yml:55  compliance:
.github/labeler.yml:5  documentation:
.github/workflows/build-deb.yml:82 --cache-control="max-age=300" \
.github/workflows/publish-meta.yml:72 --cache-control "public, max-
age=31536000, immutable"
.github/workflows/publish-meta.yml:129 --cache-control "no-cache"
.github/workflows/publish-meta.yml:134 --cache-control "no-cache"
.github/workflows/publish-meta.yml:139 --cache-control "no-cache"
```

FINDING

Does the system provide evidence of documented internal controls over financial reporting, including control objectives, control activities, and monitoring procedures, as required under SOX Section 404(a)?

REMEDIATION

Implement and document a comprehensive internal controls framework for financial reporting. Create formal documentation that includes: (1) clearly defined control objectives for financial data accuracy and completeness, (2) specific control activities such as segregation of duties, authorization procedures, and data validation controls, and (3) monitoring procedures including regular testing and evaluation of control effectiveness. Establish a dedicated controls documentation directory with version control, and ensure all financial reporting processes have corresponding control documentation that can be audited and verified.

SOX-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:64 key: ${{ runner.os }}-build-
agent-${{ env.cache-name }}-${{ hashFiles('**/package-lock.json') }}
.github/workflows/build-agent.yml:73 - name: Set repo hash
.github/workflows/build-agent.yml:75 # This forces git shorthash to
match between @medplum/agent and @medplum/core
.github/workflows/build-agent.yml:78 echo
"MEDPLUM_GIT_SHORTHASH=$(git rev-parse --short=7 HEAD)" >> $GITHUB_ENV
.github/workflows/build-agent.yml:239 key: ${{ runner.os }}-build-
agent-${{ env.cache-name }}-${{ hashFiles('**/package-lock.json') }}
.github/workflows/build-agent.yml:248 - name: Set repo hash
.github/workflows/build-agent.yml:250 # This forces git shorthash to
match between @medplum/agent and @medplum/core
.github/workflows/build-agent.yml:253 echo
"MEDPLUM_GIT_SHORTHASH=$(git rev-parse --short=7 HEAD)" >> $GITHUB_ENV
```

FINDING

Does the system implement controls to prevent unauthorized alteration or destruction of financial records, including integrity verification, immutable storage, and tamper detection mechanisms, consistent with SOX Section 802 anti-destruction requirements?

REMEDIATION

Implement comprehensive financial record protection controls including: (1) immutable audit logging with cryptographic integrity verification for all financial data operations, (2) tamper detection mechanisms that monitor and alert on unauthorized access attempts to financial records, (3) role-based access controls specifically governing financial record modifications, and (4) backup and retention policies that prevent unauthorized destruction of financial documents. Replace any data truncation operations affecting financial records with secure archival processes that maintain complete audit trails while meeting regulatory retention requirements.

TCPA

8 findings

FCC · \$500-\$1,500 per violation

TCPA-001

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
LICENSE.txt:135  the terms of any separate license agreement you may
have executed
LICENSE.txt:144  agreed to in writing, Licensor provides the Work (and
each
LICENSE.txt:156  negligent acts) or agreed to in writing, shall any
Contributor be
LICENSE.txt:171  of any other Contributor, and only if You agree to
indemnify,
NOTICE:15  Unless required by applicable law or agreed to in writing,
software
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:470
linkId: 'consent-for-treatment',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:471
text: 'Consent for Treatment',
examples/foomedical/src/pages/PatientIntakeQuestionnairePage.tsx:475
linkId: 'consent-for-treatment-signature',
```

FINDING

Does the system obtain prior express written consent before sending marketing or promotional text messages, including a clear and conspicuous disclosure that consent is being sought, as required under 47 U.S.C. §227(b)(1) and 47 CFR §64.1200(a)(2)?

REMEDIATION

Implement a comprehensive SMS consent collection system that includes: (1) clear and conspicuous disclosure language explaining that consent is being sought for marketing text messages, (2) opt-in mechanisms that capture express written consent before sending any promotional SMS, (3) database fields to store and track consent status per user, and (4) validation logic to prevent SMS marketing to users without proper consent. The consent flow should be separate from medical treatment consent and specifically address SMS marketing communications with appropriate legal disclaimers about message frequency and data rates.

TCPA-002

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/autofix-ci.yml:5  cancel-in-progress: true
.github/workflows/build-agent.yml:5  cancel-in-progress: true
.github/workflows/build-deb.yml:5    cancel-in-progress: true
.github/workflows/build-helm-charts.yml:5  cancel-in-progress: true
.github/workflows/build.yml:6         cancel-in-progress: true
.github/workflows/codeql-analysis.yml:17  cancel-in-progress: true
.github/workflows/deploy.yml:5          cancel-in-progress: false
.github/workflows/madge.yml:5          cancel-in-progress: true
```

FINDING

Does the system provide a clear and easy mechanism for recipients to opt out of receiving further messages, and does it honor opt-out requests promptly, as required under TCPA and CTIA guidelines?

REMEDATION

Implement a comprehensive opt-out system that includes: (1) clear opt-out instructions in all outbound messages (e.g., "Reply STOP to opt out"), (2) database tables to track recipient opt-out preferences, (3) API endpoints to process and honor opt-out requests, (4) automated message filtering to prevent sending to opted-out recipients, and (5) confirmation messages when opt-out requests are processed. Ensure opt-out requests are honored immediately and that the mechanism is prominently displayed in all messaging interfaces.

TCPA-003

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-agent.yml:50 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:231 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:313 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-agent.yml:395 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-deb.yml:37 registry-url:
'https://registry.npmjs.org'
.github/workflows/build-helm-charts.yml:30 registry-url:
'https://registry.npmjs.org'
.github/workflows/build.yml:39 registry-url:
'https://registry.npmjs.org'
.github/workflows/build.yml:93 registry-url:
'https://registry.npmjs.org'
```

FINDING

Does the system check phone numbers against the National Do Not Call Registry and maintain an internal do-not-call list before initiating outbound calls or messages, as required under 47 CFR §64.1200(c)?

REMEDIATION

Implement National Do Not Call Registry checking functionality by integrating with the FTC's Do Not Call Registry API or a third-party compliance service before initiating any outbound calls or SMS messages. Create and maintain an internal suppression list database table to track opt-out requests from users. Add validation logic in the communication workflow code to check both the national registry and internal suppression list before placing calls or sending messages. Ensure all outbound communication modules include these compliance checks as mandatory steps that cannot be bypassed.

TCPA-004

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/build-deb.yml:49  RECAPTCHA_SITE_KEY:
'__RECAPTCHA_SITE_KEY__'
.github/workflows/build.yml:74  RECAPTCHA_SITE_KEY:
'__RECAPTCHA_SITE_KEY__'
.github/workflows/build.yml:432  RECAPTCHA_SITE_KEY:
'__RECAPTCHA_SITE_KEY__'
.github/workflows/deploy.yml:85  RECAPTCHA_SITE_KEY: ${
secrets.RECAPTCHA_SITE_KEY }}
.github/workflows/publish.yml:90  RECAPTCHA_SITE_KEY:
'__RECAPTCHA_SITE_KEY__'
.github/workflows/staging.yml:53  RECAPTCHA_SITE_KEY:
'__RECAPTCHA_SITE_KEY__'
.github/workflows/staging.yml:85  RECAPTCHA_SITE_KEY: ${
secrets.STAGING_RECAPTCHA_SITE_KEY }}
biome.json:63  "useMediaCaption": "warn",
```

FINDING

Does the system disclose to consumers the expected frequency of messages before obtaining consent, and does it enforce frequency limits consistent with the disclosed rate, as recommended by CTIA guidelines?

REMEDIATION

Implement a comprehensive messaging compliance system that includes: (1) user-facing disclosure forms showing expected message frequency before consent collection, (2) database schema to store user consent with disclosed frequency rates, (3) rate limiting mechanisms that enforce the disclosed frequency limits, and (4) logging systems to track message sending patterns for compliance auditing. The system should present clear frequency expectations (e.g., "up to 5 messages per week") during signup and technically enforce these limits in the messaging infrastructure.

TCPA-005

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
examples/medplum-eligibility-demo/data/core/core-data.json:329
"display": "Brand Name Prescription Drug"
examples/medplum-eligibility-demo/data/core/core-data.json:449
"display": "Brand Name Prescription Drug - Formulary"
examples/medplum-eligibility-demo/data/core/core-data.json:453
"display": "Brand Name Prescription Drug - Non-Formulary"
examples/medplum-photon-integration/src/photon-types.d.ts:159
brandName?: string;
examples/medplum-provider/src/pages/getstarted/GetStartedPage.tsx:25
IconBrandDiscord,
examples/medplum-provider/src/pages/getstarted/GetStartedPage.tsx:570
<IconBrandDiscord size={24} color="var(--icon-secondary)" />
examples/medplum-valueset-selector/src/pages/HomePage.tsx:15  "id":
"rxnorm-branded-drugs",
examples/medplum-valueset-selector/src/pages/HomePage.tsx:16  "url":
"http://example.org/fhir/ValueSet/rxnorm-branded-drugs",
```

FINDING

Does the system include proper sender identification in all outbound messages, including the identity of the entity sending the message and how to contact them, consistent with TCPA and CTIA requirements?

REMEDIATION

Implement sender identification functionality for all outbound messages by adding required fields such as sender name, organization identity, and contact information (phone number, email, or physical address). Create message templates or wrapper functions that automatically include this identification data before sending any communications. Establish configuration settings to manage sender contact details and ensure they are consistently applied across all messaging channels. Add validation to prevent messages from being sent without proper sender identification.

TCPA-006

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
packages/server/src/migrations/schema/v1.ts:773  await
client.query(`CREATE TABLE IF NOT EXISTS "Consent_History" (
packages/server/src/migrations/schema/v14.ts:154  await
client.query('CREATE INDEX ON "Consent_History" ("id")');
packages/server/src/migrations/schema/v14.ts:155  await
client.query('CREATE INDEX ON "Consent_History" ("lastUpdated")');
packages/server/src/migrations/schema/v42.ts:707  'CREATE INDEX
CONCURRENTLY IF NOT EXISTS "Consent_sourceReference_idx" ON "Consent"
("sourceReferenc
```

FINDING

Does the system maintain records of consent that would be sufficient to demonstrate compliance in the event of a dispute, including the date, time, method of consent, and the specific consent language presented to the consumer?

REMEDIATION

The development team needs to implement comprehensive consent record fields within the existing Consent and Consent_History tables to capture: (1) precise timestamp of consent collection, (2) method of consent (web form, SMS, voice, etc.), (3) the exact consent language/script shown to the consumer, (4) consumer contact information, and (5) any consent withdrawal records. Additionally, implement data retention policies ensuring these records are preserved and easily retrievable for regulatory inquiries or disputes, with proper indexing for efficient lookup by consumer identifier and date ranges.

TCPA-007

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/codeql-analysis.yml:63 # If this step fails, then
you should remove it and run the build manually (see below)
.github/workflows/codeql-analysis.yml:70 # 🖋 If the Autobuild fails
above, remove it and uncomment the following three lines
.github/workflows/prepare-release.yml:33 # Upgrade to a patched
version; this should be removed after Node has a tagged
.github/workflows/scorecard.yml:26 # `publish_results: true` only
works when run from the default branch. conditional can be removed if
.github/workflows/upgrade-dependencies.yml:37 # Upgrade to a patched
version; this should be removed after Node has a tagged
LICENSE.txt:161 work stoppage, computer failure or malfunction, or
any and all
docker-compose.full-stack.yml:4 restart: unless-stopped # for
production usage, consider using 'always'
docker-compose.full-stack.yml:31 restart: unless-stopped # for
production usage, consider 'always'
```

FINDING

Does the system honor revocation of consent through any reasonable means indicated by the consumer, not limited to specific keywords, and process revocation within a reasonable timeframe, consistent with FCC guidance?

REMEDIATION

Implement a comprehensive consent revocation system that monitors for revocation requests through multiple channels (SMS replies, email responses, web forms, phone calls). The system should use flexible natural language processing to detect revocation intent beyond specific keywords (e.g., "STOP", "UNSUBSCRIBE", "REMOVE ME", "NO MORE"). Build automated workflows to process revocation requests within 24-48 hours maximum, maintain revocation logs with timestamps, and ensure revoked consent is immediately honored across all communication

channels. Include testing frameworks to verify revocation handling works correctly under various scenarios.

TCPA-008

HIGH RISK

REGULATORY STANDARD

EVIDENCE

```
.github/workflows/codeql-analysis.yml:26  schedule:
.github/workflows/scorecard.yml:12  schedule:
.github/workflows/upgrade-dependencies.yml:14  schedule:
examples/foomedical/README.md:85  The "Get Care" page is configured to
search for availability with service-type "office-visit". Confi
examples/foomedical/README.md:88  "resourceType": "Schedule",
examples/foomedical/src/pages/GetCarePage.tsx:6  import { Document,
Scheduler, useMedplum } from '@medplum/react';
examples/foomedical/src/pages/GetCarePage.tsx:16  const [schedule,
loading] = useSearchOne('Schedule');
examples/foomedical/src/pages/GetCarePage.tsx:19  if (!schedule) {
```

FINDING

Does the system enforce time-of-day restrictions for outbound calls and messages, ensuring they are not sent before 8:00 AM or after 9:00 PM in the recipient's local time zone, as required under 47 CFR §64.1200(c)(1)?

REMEDIATION

Implement time-of-day validation controls that check recipient local time zones before sending any outbound calls or messages. This should include: (1) recipient timezone detection/storage, (2) validation logic that prevents communications outside 8:00 AM - 9:00 PM windows, (3) queuing mechanisms to defer messages until permitted hours, and (4) integration of these controls into all outbound communication pathways including the appointment reminder bots and any other messaging systems. The existing scheduling infrastructure in the codebase could be extended to support these TCPA compliance requirements.

WHAT THIS ANALYSIS COVERS

OpenDocket scans source code patterns — specifically whether code handles regulated data in compliance-aware ways. It searches for evidence of encryption, access controls, consent mechanisms, audit logging, and other patterns that regulators look for.

WHAT IT DOES NOT COVER

- Only public repository content is analyzed
- Files in .gitignore are not scanned
- Infrastructure, deployment, and cloud configuration are outside scope
- Operational policies and procedures are outside scope
- This analysis covers code at time of scan — changes after scan date are not reflected

LEGAL LIMITATIONS

- **This report is not defensible in court**
- It does not constitute legal advice
- It does not satisfy regulatory audit requirements
- To obtain a defensible compliance assessment, engage a licensed compliance attorney and certified auditor
- OpenDocket provides directional guidance only

HOW FINDINGS ARE GENERATED

- Primary analysis by Claude Sonnet (Anthropic)

- Independent review by Gemini 1.5 Flash (Google)
- Question libraries are open source and community-maintained
- All questions cite regulatory source text
- Questions have not been validated by a licensed attorney

HOW TO USE THIS REPORT

- Share with your engineering lead for remediation planning
- Share with your attorney as a starting point for compliance review
- Re-scan after remediation to track progress
- **Do not present this as proof of compliance**

Findings based on OpenDocket's open source question libraries. [View and contribute](#)